



南开大学
Nankai University

南开大学 软件工程课程报告

校园电信诈骗上报与预警平台

软件需求分析文档

姓名：姚鑫秋、巩岱松、郭子涵
李浩桐、谭诗洋

学号：2312664、2312325、2312145
2312711、2314003

指导教师：徐思涵

指导助教：周英楠

摘 要

近年来，电信网络诈骗犯罪高发，在校大学生因社会经验不足成为受害群体中增长最快的细分人群。然而目前高校反诈工作仍普遍停留在通知转发和海报张贴阶段，缺乏系统化的信息收集、流转与预警工具。本文档针对这一现实痛点，对“校园电信诈骗上报与预警平台”进行完整的需求分析。文档从项目背景出发，明确了系统面向普通学生、审核管理员和系统管理员三类用户角色的定位，确立了“低门槛上报、快速流转处理、精准预警推送、持续安全教育”的建设目标。通过用例建模方法，文档详细描述了诈骗事件上报、事件审核与状态管理、预警信息发布、诈骗案例知识库、安全意识测验、个人中心与上报追踪、权限管理与审计日志共七大核心功能模块，并给出各模块的用例描述。在非功能性需求部分，文档量化了响应时间、并发、安全性、可用性、可维护性等指标。最后，文档以 ER 图形式给出数据实体关系，梳理关键数据字典，并明确技术约束与基本假设。本文档为后续系统设计与原型开发奠定基础。

关键词：校园反诈；需求分析；用例建模；预警系统；UML；RBAC；隐私保护

目录

一、 引言	1
(一) 编写目的	1
(二) 项目背景	1
1. 社会背景	1
2. 现有痛点	2
3. 系统定位	3
(三) 术语与缩写说明	3
二、 系统概述	4
(一) 系统目标与范围	4
1. 系统目标	4
2. 系统范围	4
3. 系统整体架构	5
(二) 用户角色定义	6
1. 普通学生 (Student)	6
2. 审核管理员 (Reviewer)	7
3. 系统管理员 (SysAdmin)	7
4. 角色权限对比	8
5. 平台用户访问流程	8
(三) 系统运行环境	9
1. 硬件环境	9
2. 软件环境	10
3. 网络环境	10
三、 功能性需求	11
(一) 系统用例图	11
(二) 用例描述	11
1. UC-00: CAS 单点登录	12
2. UC-01: 上报诈骗事件	13

3.	UC-02: 查看个人中心与上报追踪	14
4.	UC-03: 浏览预警信息	14
5.	UC-04: 浏览诈骗案例知识库	15
6.	UC-05: 参与安全意识测验	16
7.	UC-06: 审核事件	17
8.	UC-07: 发布预警信息	18
9.	UC-08: 管理知识库条目	19
10.	UC-09: 维护题库与发起指定测验	20
11.	UC-10: 账号与权限管理	21
(三)	事件状态流转机制	21
1.	设计原则	21
2.	草稿状态的特殊处理	22
3.	终态后的二次行为	22
4.	状态流转图	22
四、	非功能性需求	23
(一)	准确性与可靠性	23
(二)	性能与及时性	24
(三)	安全性	24
1.	身份认证与会话管理	24
2.	权限控制	24
3.	传输安全与审计	25
(四)	易用性与美观性	25
(五)	兼容性	25
(六)	可维护性与标准性	26
(七)	先进性与可扩展性	26
(八)	合规性	27
(九)	非功能性需求汇总	27
五、	数据需求	28

- (一) 数据需求概述 28
 - 1. 编写目的 28
 - 2. 数据建模方法 28
 - 3. 数据分类 29
- (二) 主要数据实体及其关系 29
 - 1. 实体识别清单 29
 - 2. 系统整体 ER 图 30
 - 3. 核心实体关系详细说明 31
 - 4. 关键业务规则约束 32
 - 5. 核心业务数据流图 33
- (三) 关键数据字典 35
 - 1. 用户与权限域 35
 - 2. 事件上报域 36
 - 3. 预警与知识库域 39
 - 4. 安全教育域 41
 - 5. 系统支撑域 43
- (四) 数据完整性约束 45
 - 1. 实体完整性 45
 - 2. 参照完整性 46
 - 3. 用户自定义完整性 47
- (五) 数据安全性与隐私需求 47
 - 1. 敏感字段分级 47
 - 2. 加密存储要求 48
 - 3. 匿名上报数据隔离机制 48
 - 4. 数据保留与销毁策略 49
- (六) 数据量估算与索引设计建议 49
 - 1. 数据规模估算 49
 - 2. 关键索引设计建议 50
 - 3. 数据归档策略 51

六、 约束与假设	52
(一) 技术约束	52
1. 开发语言与框架约束	52
2. 数据库与存储约束	53
3. 接入与认证约束	53
4. 部署与运维约束	53
5. 客户端兼容性约束	54
6. 技术约束汇总	54
(二) 业务约束	54
1. 法律法规约束	54
2. 学校管理制度约束	55
3. 业务流程约束	55
4. 业务约束汇总	56
(三) 假设条件	56
1. 用户行为假设	56
2. 技术环境假设	57
3. 业务运行假设	57
4. 假设条件汇总	58
(四) 约束与假设的整体说明	58

一、引言

(一) 编写目的

本文档为《校园电信诈骗上报与预警平台》软件系统的需求分析文档。文档旨在系统、完整地描述该平台的建设背景、功能需求、非功能需求、数据需求及相关约束，供项目团队成员、指导教师及后续系统设计人员参考使用。

具体而言，本文档的主要目的如下：

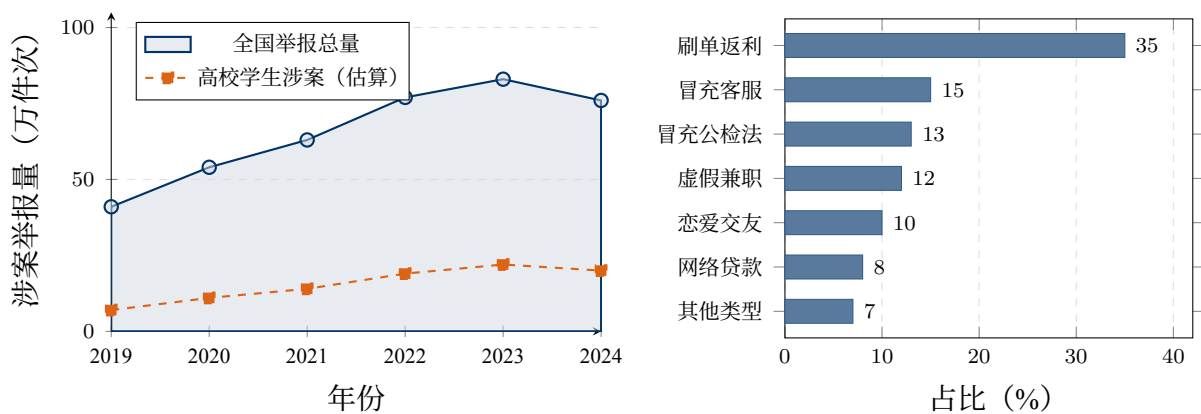
- (1) **明确需求边界：**通过结构化的需求描述，厘清系统需要“做什么”，防止后续设计阶段因需求模糊导致方向偏差。
- (2) **指导系统设计：**作为后续概要设计、详细设计与原型开发的输入依据，确保设计工作有据可查、有章可循。
- (3) **便于沟通协作：**为项目团队内部各角色（开发、测试、运营）以及潜在的利益相关者（学校保卫处、学生处等）提供统一的信息参考基础，减少沟通歧义。
- (4) **建立验收基线：**作为未来系统测试与交付验收的依据，确保最终交付物符合预期功能与质量指标。

本文档的预期读者为本课程项目团队成员及软件工程课程指导教师，兼顾学校网络安全、学生工作等相关职能部门的参考需求。

(二) 项目背景

1. 社会背景

近年来，电信网络诈骗已成为我国发案率最高的刑事犯罪类型之一。公安部数据显示，涉诈案件连年攀升，而在校大学生由于社会经验不足、防范意识薄弱，逐渐成为受害群体中增长最快的细分人群。刷单返利、虚假兼职招聘、冒充客服退款三类手法在高校学生涉诈案件中占比超过 60%。2022 年 9 月，《中华人民共和国反电信网络诈骗法》正式施行，明确要求教育主管部门和高等院校将反诈宣传教育纳入日常教学管理，并建立相关信息上报与处置机制。



(a) 2019—2024 年全国电信网络诈骗举报量趋势 (b) 高校学生涉诈案件类型分布 (%)

图 1.1: 电信网络诈骗态势概览 (数据来源: 公安部年度通报)

2. 现有痛点

当前高校反诈工作存在以下四大核心问题:

- (1) 信息孤岛: 学生遭遇诈骗后不知向谁反映; 即便反映, 信息也往往止步于辅导员个人, 无法形成全校层面的数据汇聚, 管理部门难以掌握受害真实规模。
- (2) 响应滞后: 从事件发生到全校预警发出, 往往需要数天, 而诈骗手法传播极快, 同一手法可能在预警发布前已有多名学生相继受害。
- (3) 无案可查: 大多数轻微受损事件中, 学生选择沉默, 既未留存证据, 也未上报, 管理部门无法建立有效的反诈知识积累。
- (4) 教育形式单一: 当前反诈教育以被动接收为主, 缺乏互动性, 难以有效检验学生是否真正掌握防范知识。



图 1.2: 当前高校反诈工作四大核心痛点

3. 系统定位

本平台面向全校师生，以“低门槛上报、快速流转处理、精准预警推送、持续安全教育”为核心目标，构建一个闭环的校园反诈信息管理系统。平台本身不承担侦查或执法职能，而是作为学校管理部门与在校学生之间的信息桥梁，以及全校反诈知识积累与传播的载体，在合法合规的前提下最大限度降低在校学生遭受电信诈骗的风险。

(三) 术语与缩写说明

表 1.1: 术语与缩写说明表

术语/缩写	全称	含义说明
SRS	Software Requirements Specification	软件需求规格说明书，本文档所属文档类型
UML	Unified Modeling Language	统一建模语言，用于系统建模与需求可视化
RBAC	Role-Based Access Control	基于角色的访问控制模型，用于平台权限管理
UC	Use Case	用例，描述系统与参与者之间的交互场景
ER 图	Entity-Relationship Diagram	实体关系图，用于描述数据模型中实体及其关系
Student	—	普通学生角色，系统最主要使用群体
Reviewer	—	审核管理员角色，负责事件审核与处置
SysAdmin	System Administrator	系统管理员角色，负责平台运维与合规管理
KPI	Key Performance Indicator	关键绩效指标，用于衡量系统运营效果
案件编号	—	系统自动生成的唯一事件标识，格式：年份-院系代码-流水号
脱敏	—	数据脱敏处理，指去除或遮盖数据中可识别个人身份的信息
站内通知	—	平台内部消息通知系统，用于向用户推送系统消息
匿名上报	—	上报者信息在管理员界面隐藏的上报方式，系统后台仍记录真实身份
预警等级	—	分为“提示”“警告”“紧急”三级，对应不同风险严重程度
CAS	Central Authentication Service	统一身份认证服务，学校统一登录系统

二、系统概述

(一) 系统目标与范围

1. 系统目标

校园电信诈骗上报与预警平台旨在通过信息化手段，在学校管理部门与在校学生之间构建一个高效、闭环的反诈信息流转机制，实现以下四项核心目标：

- (1) 低门槛上报：提供简洁易用的事件上报入口，学生在遭遇或发现疑似诈骗后，可通过简单操作完成事件提交，同时保障上报者的隐私安全选择权。
- (2) 快速流转处理：建立事件状态流转机制，确保每一条上报均得到及时响应与处置，系统自动向管理员推送待处理通知，减少人工协调成本，力争平均处理时长不超过 48 小时。
- (3) 精准预警推送：依托真实上报案例，支持管理员快速发布分级预警，并按院系或全校范围精准推送至目标学生群体，将预警发布时间从事件发生后的数天压缩至数小时内。
- (4) 持续安全教育：以情景化互动测验替代传统被动宣教，并建立可检索的反诈知识库，将上报案例转化为可复用的教育资源，提升全校学生安全意识水平。

2. 系统范围

本平台的功能边界如下所述。

系统内 (In Scope)：

- 学生端：诈骗事件在线上报、上报进度查看与追踪、预警信息浏览、知识库内容浏览、安全意识测验参与、个人中心管理。
- 审核管理员端：事件审核与状态管理、预警信息发布、知识库条目创建与管理、安全意识测验题库维护与发起。
- 系统管理员端：用户账号创建/停用/角色变更、系统参数配置、审计日志查阅。

系统外 (Out of Scope)：

- 平台不承担任何侦查、执法或司法协助的主动职能，对接公安机关的操作由管理员线下完成。
- 平台不直接与外部公安系统、金融机构系统或运营商系统进行实时数据对接。

- 平台不涉及受害学生的经济损失赔偿、保险理赔或法律援助业务。
- 平台服务对象限于本校在读学生及教职工，不对校外社会人员开放注册。

3. 系统整体架构

平台采用分层分域架构设计，共分为用户层、客户端层、接入网关层、应用服务层、数据存储层和运维监控层六层，各层职责清晰、边界明确，层间通过标准协议进行交互，整体架构如图 2.1 所示。

各层具体职责如下：

用户层定义三类角色主体：普通学生（全校在读师生）负责事件上报与安全知识学习；审核管理员（辅导员/保卫处工作人员）负责事件核实与预警发布；系统管理员（信息中心人员）负责账号权限管理与系统运维配置，三类角色均通过学校 CAS 统一身份认证接入系统，访问权限遵循最小特权原则严格隔离。

客户端层采用 Vue 3 + TypeScript + Element Plus 构建前端单页应用（SPA），支持响应式布局，兼容 iOS Safari 13+ 及 Chrome for Android 80+ 等主流移动端浏览器，通过 HTTPS/TLS 加密信道与接入网关层通信。

接入网关层部署 Nginx 作为系统唯一对外入口，承担 TLS 1.2+ 终止、静态资源服务、REST API 路由分发及 HTTP 到 HTTPS 强制跳转四项职能，是内外网流量隔离与安全边界控制的关键节点。

应用服务层基于 FastAPI 构建，分为业务功能模块与横切基础服务两层：前者涵盖事件上报（UC-01）、进度追踪（UC-02）、预警浏览/发布（UC-03）、知识库（UC-04）、安全测验（UC-05/09）、事件审核（UC-06）、数据看板（UC-07）及账号管理（UC-11）八个业务模块；后者提供通知服务、审计日志、CAS 集成、文件加密、会话管理、ID 生成（雪花算法）、定时任务和 RBAC 权限校验八项共享能力，通过 REST API 对上层暴露统一接口。

数据存储层采用三类异构存储引擎：MySQL 8.0+（主从复制，InnoDB 引擎，utf8mb4 编码）承担关系型业务数据的持久化；Redis 7.0+ 提供会话缓存、热点数据加速与轻量消息队列；NAS/S3 对象存储通过 AES-256-CBC 信封加密保存上报附件，加密密钥由独立 KMS 托管，实现密钥与密文的物理隔离存储。

运维监控层以旁路采集方式接入，不影响业务主链路性能：ELK Stack（Elasticsearch + Logstash + Kibana）提供全链路日志收集、检索与可视化；Prometheus + Grafana 实现性能指标采集、阈值告警与监控大盘；所有服务统一容器化部署（Docker + Kubernetes/systemd），保障平台弹性扩展与运维自动化。

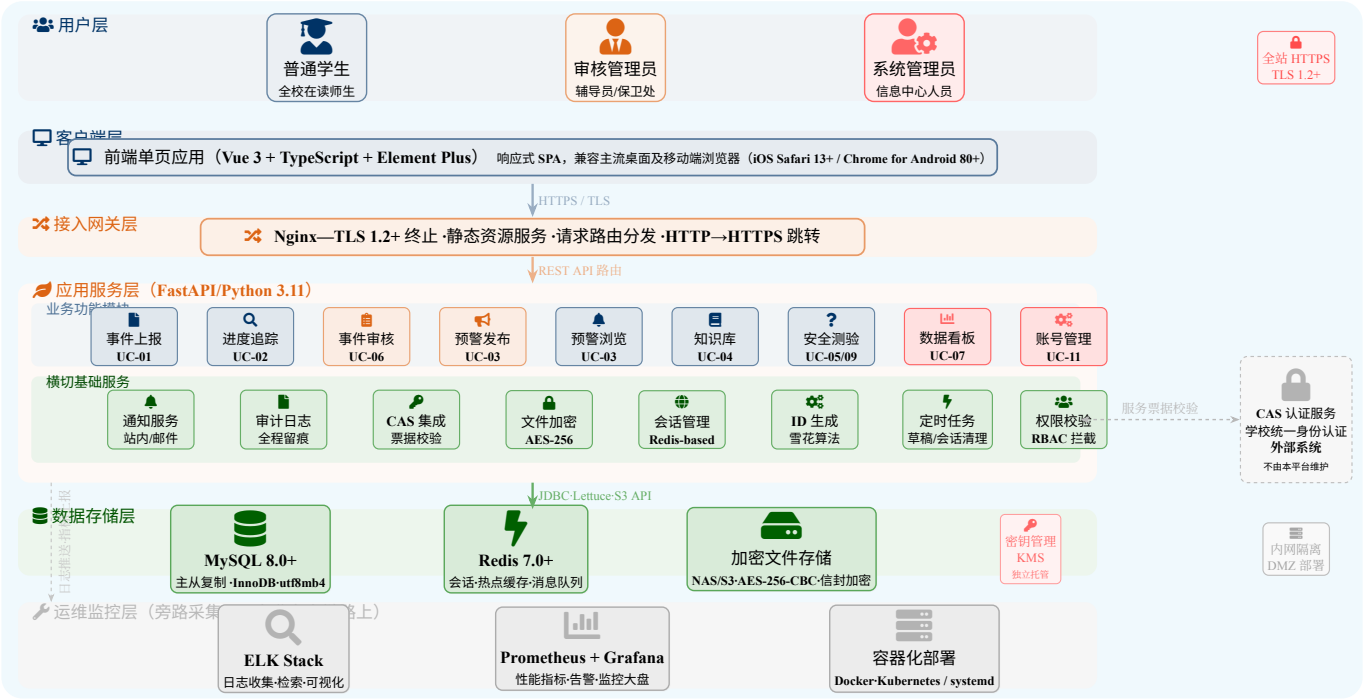


图 2.1: 校园电信诈骗上报与预警平台系统整体架构图

(二) 用户角色定义

本平台定义三类用户角色，各角色的职责边界、权限范围与典型使用场景如下。

1. 普通学生 (Student)

角色概述：系统最主要的使用群体，包括全校在读本科生、研究生及留学生，通过学校 CAS 统一身份认证账号登录平台。

主要诉求：

- 在遭遇或发现疑似诈骗后，能以最低操作成本完成事件上报（不超过 3 步）；
- 上报后能实时跟踪事件处理进展，获得完整的闭环反馈；
- 主动获取预警信息和防范知识，提升自身安全意识；
- 对个人隐私信息（尤其是选择匿名上报时）有较强的保护诉求。

权限范围：

- 可访问：自身上报记录及处理进展、个人系统通知、公开预警列表、知识库全部内容、安全意识测验；
- 不可访问：他人上报记录任何信息、管理员内部处理备注、审计日志、系统管理功能。

典型使用场景：某同学收到陌生人发来的刷单兼职邀请，怀疑为诈骗，通过平台匿名上报该事

件；随后在个人中心查看案件处理进度；同时参与平台推送的“求职季”主题安全意识测验，了解该类诈骗的识别方法。

2. 审核管理员 (Reviewer)

角色概述：由各院系辅导员或学校保卫处、学生处工作人员担任，负责对学生上报事件进行内容核实、分类审核和处置跟进。同一事件可能经由院系级管理员初步处理后，上报至学校级管理员进行统一归档和预警决策。审核管理员需要较高的操作权限，其操作行为全程受审计监控。

主要职责：

- 及时审核学生上报事件，对各事件进行内容核实、分类和状态更新；
- 将经核实的典型案例整理为脱敏摘要，录入知识库供全校学生参阅；
- 根据案例情况判断并发布适当等级的预警信息；
- 组织发起面向特定学生群体的安全意识指定测验，并跟踪完成情况。

权限范围：

- 可访问：所有事件完整内容（含上报者联系方式等敏感信息，访问行为强制记录至审计日志）、知识库管理、预警发布；
- 不可访问：系统账号管理功能、完整审计日志（仅可查看自身操作记录）。

角色层级说明：审核管理员在组织上分为院系级（**Department-Reviewer**）与学校级（**School-Reviewer**）两个层级，但二者在系统中共享同一 Reviewer 角色基线，区别仅在于业务作用域：院系级负责本院系上报事件的初审与一线处置；学校级负责跨院系归档、知识库条目终审、全校预警决策。本文档中如未特别区分，“审核管理员”泛指上述两层。

3. 系统管理员 (SysAdmin)

角色概述：负责整个平台的运维管理，通常由学校信息中心或网络安全相关部门的技术人员担任，不直接参与具体业务事件的处理。其存在主要保障平台的合规运行和数据安全。

主要职责：

- 创建、停用、变更用户账号及其角色归属；
- 配置系统参数（如预警推送渠道、审计日志保留策略、文件加密密钥轮转等）；
- 查阅完整审计日志，确保平台所有操作合规可溯；
- 在特殊情况下，经授权查看匿名上报者真实身份信息并留存查阅记录。

权限范围：

- 可访问：用户账号管理、系统参数配置、完整审计日志；
- 不可访问：业务事件内容的直接审核或修改、预警发布、知识库内容审核；唯一例外是经书面授权的司法协助查询匿名上报者身份（UC-11 备选 A2），该操作不构成业务审核权，仅为合规协查通道，且全程审计并向所有系统管理员告警。

4. 角色权限对比

三类角色的权限边界对比如表 2.1 所示。

表 2.1: 用户角色权限对比表

功能模块	普通学生	审核管理员	系统管理员
上报诈骗事件	✓	×	×
查看自身上报记录与进展	✓	—	—
查看所有事件（含敏感信息）	×	✓（审计）	×
事件审核与状态管理	×	✓	×
发布预警信息	×	✓	×
管理知识库条目	×	✓	×
浏览知识库与预警（公开内容）	✓	✓	✓
参与安全意识测验	✓	—	—
维护题库与发起指定测验	×	✓	×
账号创建/停用/角色变更	×	×	✓
查阅完整审计日志	×	×	✓
系统参数配置	×	×	✓

注：“✓”表示具有该权限，“×”表示无该权限，“-”表示该角色不涉及此功能场景。

5. 平台用户访问流程

平台采用分层分域架构设计，共分为用户层、客户端层、接入网关层、应用服务层、数据存储层和运维监控层六层，各层职责清晰、边界明确，整体架构如图 2.1 所示。

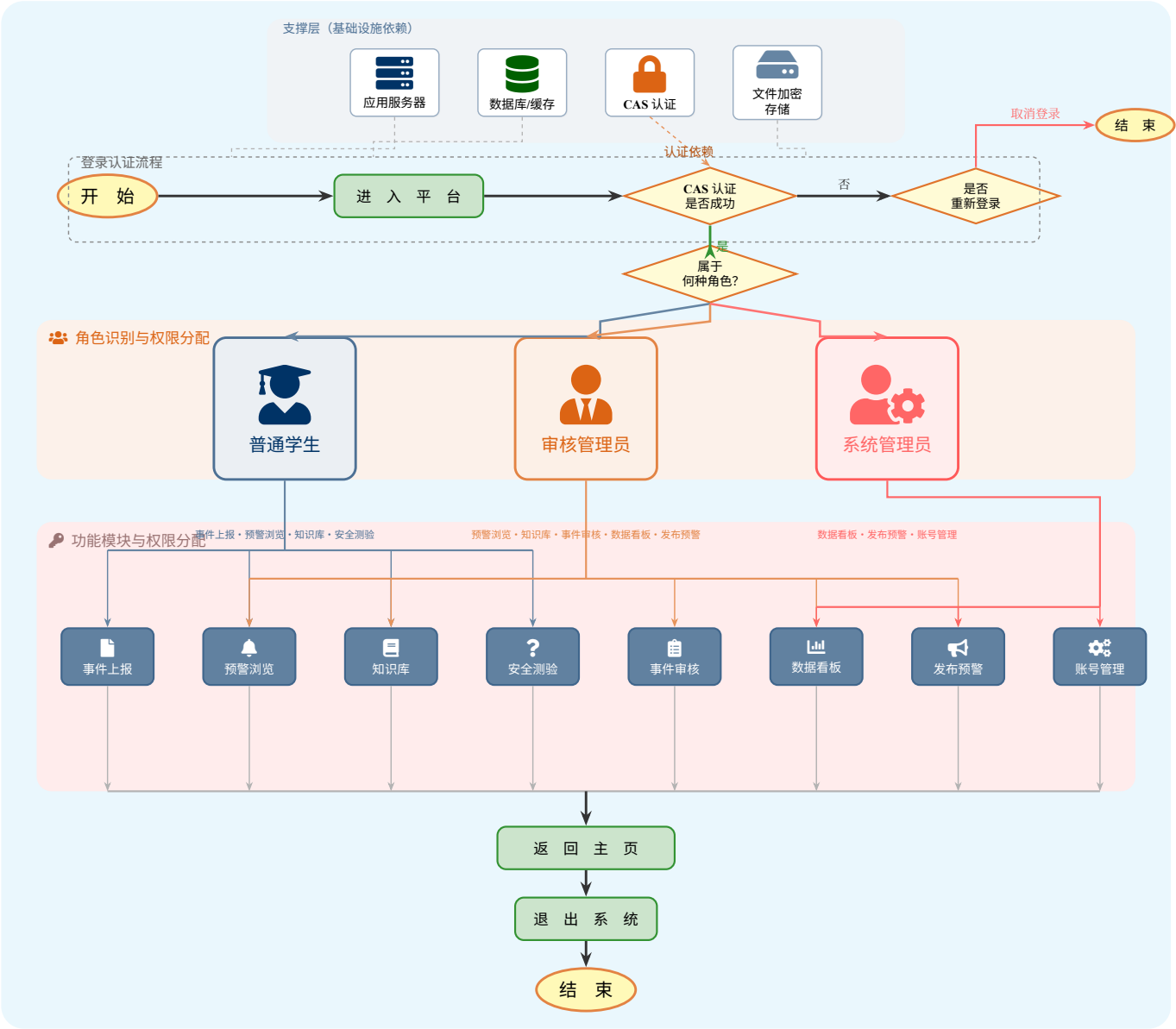


图 2.2: 校园电信诈骗上报与预警平台——用户访问流程与角色功能分布图

(三) 系统运行环境

1. 硬件环境

系统运行所需的硬件配置要求如表 2.2 所示。

表 2.2: 系统运行硬件环境要求

设备类型	部署位置	最低配置要求
应用服务器	学校数据中心	CPU ≥ 4 核; 内存 ≥ 8 GB; 系统盘 ≥ 100 GB SSD; 支持弹性扩展或容器化部署
数据库服务器	学校数据中心	CPU ≥ 4 核; 内存 ≥ 16 GB; 存储 ≥ 1 TB (RAID-5 冗余), 预留证据图片存储扩容空间
文件存储服务	学校数据中心	独立对象存储或 NAS, 初始容量 ≥ 2 TB, 用于加密存储证据图片文件
用户终端	用户侧	PC 或移动端现代浏览器 (Chrome 80+ / Firefox 75+ / Edge 80+ / iOS Safari 13+ / Chrome for Android 80+); 网络带宽 ≥ 4 Mbps

2. 软件环境

系统运行所需的软件环境要求如表 2.3 所示。

表 2.3: 系统运行软件环境要求

软件层次	具体要求
服务器操作系统	Linux (Ubuntu Server 22.04 LTS 或 CentOS Stream 9), 支持 Docker/Kubernetes 容器化部署
后端运行时	Python 3.11+ (FastAPI 0.110+) 作为主要后端框架; Uvicorn +Gunicorn 作为 ASGI 服务器; Nginx 1.24+ 作为反向代理与静态资源服务器
数据库系统	MySQL 8.0+ 作为主关系型数据库; Redis 7.0+ 用于会话管理、消息队列与热点数据缓存
前端运行环境	现代浏览器 (支持 ES6+), 采用响应式 Web 设计兼容移动端浏览器访问
安全组件	HTTPS/TLS 1.2+ 全站加密传输; 文件加密存储 (AES-256); 对接学校 CAS 单点登录系统进行实名认证
监控与运维	Prometheus + Grafana 用于系统性能监控与告警; ELK Stack 用于日志收集与分析

3. 网络环境

平台部署于学校校园网数据中心内, 通过学校统一出口对外提供服务, 网络环境要求如下:

- 内网访问: 校内用户通过学校内网或 VPN 访问平台, 确保访问速度与稳定性, 延迟应 ≤ 50 ms。
- 外网访问: 支持学生通过公网访问平台 (如假期期间), 外网访问须经过学校防火墙过滤与 TLS 加密传输。
- 带宽要求: 服务器侧互联网出口带宽建议 ≥ 100 Mbps, 以保障开学初等高并发访问场景。
- 安全隔离: 数据库服务器与文件存储服务器部署于内网隔离区 (DMZ), 不直接暴露于公网, 仅通过应用服务器经受控接口进行访问。

三、 功能性需求

(一) 系统用例图

系统共包含三类参与者：普通学生 (Student)、审核管理员 (Reviewer)、系统管理员 (SysAdmin)，以及 11 个用例（其中 UC-00 为公共基础用例，UC-01 至 UC-09 与 UC-10 共 10 个为核心业务用例）。用例图 3.1 直观呈现各角色与用例的关联关系：蓝色用例仅学生可触达，橙色用例由审核管理员主导，灰色椭圆为多角色共享用例，红色用例由系统管理员专属操作，绿色用例为全体角色共享的公共基础用例。

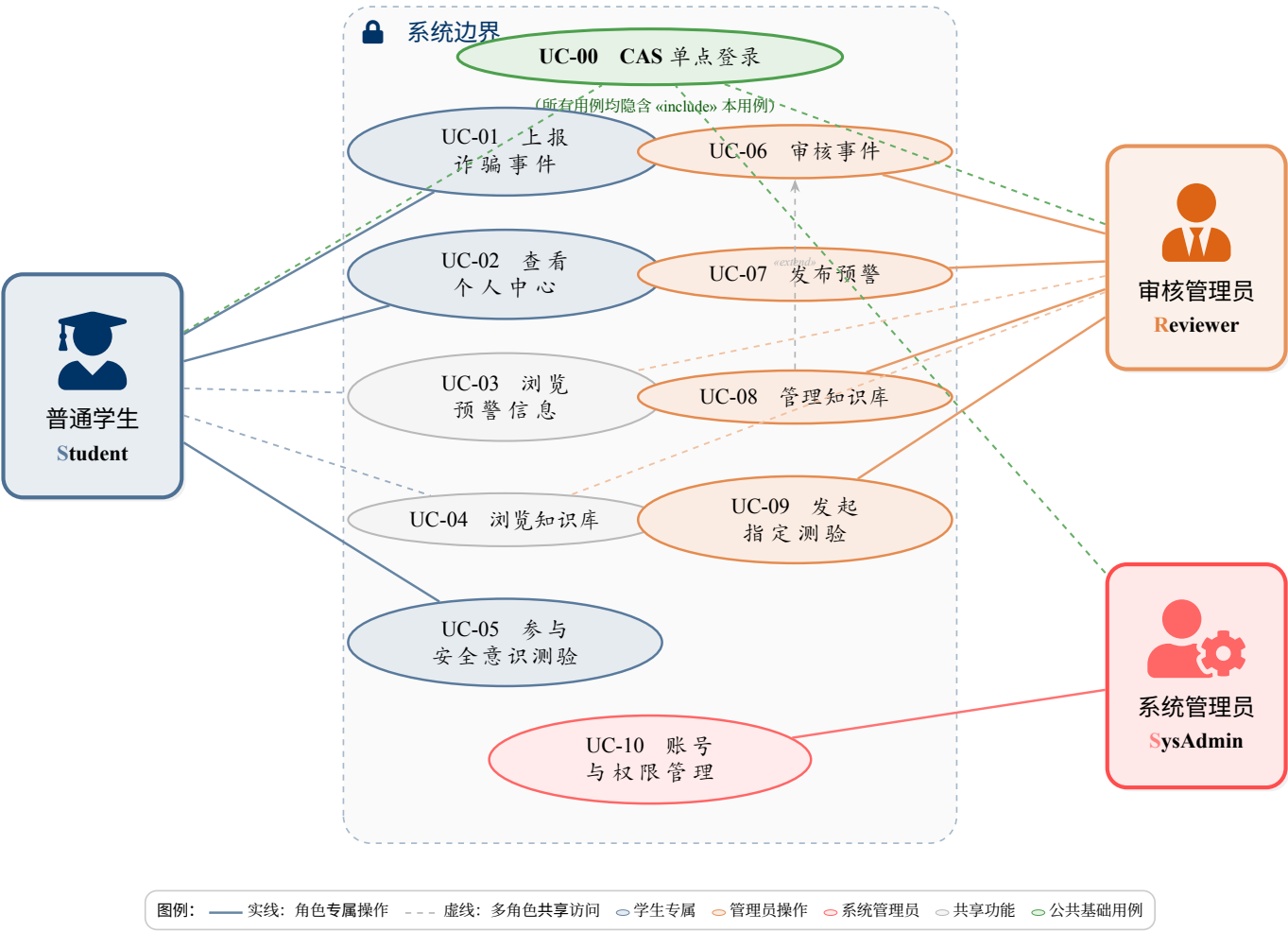


图 3.1: 校园电信诈骗上报与预警平台系统用例图

(二) 用例描述

本节对各核心用例进行结构化描述，包含用例编号、名称、参与者、前置条件、后置条件、基本事件流和备选事件流。

1. UC-00：CAS 单点登录

说明：UC-00 为平台的公共基础用例，UC-01 至 UC-10 在执行前均隐含 «include» UC-00。为避免用例图过度拥挤，图 3.1 中只绘制三类参与者与 UC-00 的直接关联线。

表 3.1: UC-00 用例描述：CAS 单点登录

UC-00 CAS 单点登录	
用例编号	UC-00
用例名称	CAS 单点登录
参与者	普通学生（Student）、审核管理员（Reviewer）、系统管理员（SysAdmin）
前置条件	用户拥有有效的学校 CAS 账号；用户终端可访问校园网或经认证的校外网络；目标平台账号未被停用
后置条件	系统在服务器端建立用户会话（Session）；用户被引导至与其角色对应的工作台首页；本次登录行为完整记录至审计日志（用户名、时间戳、来源 IP、终端类型）
基本事件流	1. 用户在浏览器中访问平台入口 URL。 2. 系统检测当前请求未携带有效会话凭证，自动重定向至学校 CAS 认证页面。 3. 用户在 CAS 页面输入校园账号（学号/工号）及密码，点击“登录”。 4. CAS 服务器校验账户凭证；通过后生成一次性服务票据（Service Ticket），重定向回平台并附带票据参数。 5. 平台后端调用 CAS 服务器的票据校验接口，确认票据有效性，并获取用户实名信息（姓名、学号/工号、所在院系）。 6. 系统根据实名信息查询本地账号表，确认其角色（Student / Reviewer / SysAdmin）；若为本地无记录的合法师生身份，则自动以 Student 角色完成首登注册。 7. 系统创建会话并下发会话 Cookie，跳转至该角色对应的工作台首页（学生跳转至个人中心，管理员跳转至待办工作台）。 8. 系统将本次登录的时间戳、用户标识、来源 IP、终端类型写入审计日志。
备选事件流	A1. 凭证错误：CAS 校验失败，CAS 页面提示“账号或密码错误”，用户可重新输入；连续 5 次错误，CAS 自动锁定账号 30 分钟（由 CAS 服务器统一管控，本平台不重复实现）。 A2. 票据校验失败：平台收到 CAS 回跳但票据校验未通过（票据过期或被篡改），系统拒绝建立会话，引导用户返回入口重新发起认证。 A3. 账号被停用：CAS 校验通过，但本地账号状态为“已停用”（由 UC-10 系统管理员设置），系统不创建会话，提示“账号已被停用，请联系管理员”，并将该次失败登录记入审计日志。 A4. CAS 服务不可用：平台无法连通 CAS 服务器（网络故障或 CAS 维护窗口），登录页面提示“统一身份认证服务暂时不可用，请稍后重试”，期间禁止任何业务功能访问。 A5. 会话超时自动退出：用户登录后连续 30 分钟无操作，系统自动失效会话；下次访问任意业务页面时，重新触发本用例从步骤 1 开始。 A6. 用户主动退出：用户在任意页面点击“退出登录”，系统销毁会话 Cookie 并跳转至 CAS 登出端点，统一注销。
包含用例	记录审计日志
扩展用例	—

2. UC-01: 上报诈骗事件

表 3.2: UC-01 用例描述：上报诈骗事件

UC-01 上报诈骗事件	
用例编号	UC-01
用例名称	上报诈骗事件
参与者	普通学生 (Student)
前置条件	学生已通过学校 CAS 统一身份认证登录系统
后置条件	事件进入“待审核”队列；系统自动分配唯一案件编号；相关审核管理员收到新上报站内通知
基本事件流	1. 学生在首页点击“我要上报”按钮，进入事件上报表单页面。 2. 学生从预设分类（刷单返利类、冒充公检法类、虚假兼职招聘类、恋爱交友诈骗类、冒充客服退款类、虚假网络贷款类、游戏账号交易诈骗类及其他类型）中选择诈骗事件类型，系统展示该类型的简要说明辅助判断。 3. 学生填写事件基本信息：发生日期（精确到日）、事件经过文字描述（系统实时显示字数，建议不少于 200 字）、涉及金额（可填 0 或选择“仅遭遇未受损”）、诈骗方式（电话/短信/社交软件/邮件/网页等多选）、涉及平台或应用名称。 4. 学生选择性上传证据材料（图片截图，最多 10 张，单张文件不超过 5 MB）。 5. 学生选择上报方式：“实名上报”或“匿名上报”。 6. 学生点击“提交”按钮。 7. 系统对表单进行完整性与格式校验；校验通过后，系统对证据文件进行 AES-256 加密处理并存储。 8. 系统生成唯一案件编号（格式：年份-院系代码-流水号），显示提交成功页面并发送站内通知至学生个人中心。
备选事件流	A1. 必填项未完成：系统高亮标注缺失字段并提示“请完善必填信息”，不允许提交，流程返回步骤 3。 A2. 文件格式或大小不符：系统在上传时即时提示“仅支持 JPG/PNG/GIF 格式，单张不超过 5 MB”，拒绝该文件，其余已上传文件保留。 A3. 涉案金额超过 5000 元：系统在步骤 5 前弹窗提示“损失金额较大，建议实名上报以便工作人员与您取得联系”，学生确认后继续流程。 A4. 网络异常提交失败：系统提示“提交失败，内容已暂存草稿”，学生可在个人中心“草稿箱”继续编辑并重新提交。
包含用例	文件格式校验与加密上传、发送站内通知
扩展用例	—

3. UC-02：查看个人中心与上报追踪

表 3.3: UC-02 用例描述：查看个人中心与上报追踪

UC-02 查看个人中心与上报追踪	
用例编号	UC-02
用例名称	查看个人中心与上报追踪
参与者	普通学生（Student）
前置条件	学生已登录系统
后置条件	学生获取上报进度与系统通知信息（只读操作，无数据状态变更）
基本事件流	1. 学生进入“个人中心”页面，查看基本信息区（姓名、院系、学号、注册邮箱、反诈教育完成情况标记）。 2. 学生点击“我的上报”，以时间线形式查看历史上报事件列表（含案件编号、上报时间、诈骗类型、当前状态）。 3. 学生点击某一上报记录，查看该事件完整处理进展：各状态变更的时间节点及管理员对外反馈说明（管理员内部备注对学生不可见）。 4. 学生进入“通知中心”，查看所有相关系统通知（上报状态变更、预警推送、测验发布等），未读通知以醒目标记提示；点击通知后自动标记为已读。 5. 学生在“隐私设置”区管理绑定邮箱或修改登录密码（实名信息不支持修改）。
备选事件流	A1. 存在未完成草稿：个人中心顶部显示提示横幅“您有 1 份未完成的上报草稿”，学生可点击直接跳转继续编辑（扩展至 UC-01 的草稿续填流程）。
包含用例	—
扩展用例	继续编辑草稿上报（扩展 UC-01）

4. UC-03：浏览预警信息

表 3.4: UC-03 用例描述：浏览预警信息

UC-03 浏览预警信息	
用例编号	UC-03
用例名称	浏览预警信息
参与者	普通学生（Student）
前置条件	学生已登录系统；系统中存在已发布的预警信息
后置条件	预警阅读状态更新，无其他数据变更
基本事件流	1. 学生登录后，若首页顶部存在最新预警横幅（“警告”或“紧急”级），学生可直接点击查看详情。 2. 学生亦可进入“预警信息”列表页，查看所有历史预警（按发布时间倒序排列，支持按预警等级筛选）。 3. 学生点击某条预警记录，查看完整预警内容（标题、正文、防范建议、预警等级标识）。 4. 若预警关联了案例编号，学生可点击查看对应的脱敏原始案例摘要（跳转至知识库对应条目）。
备选事件流	A1. 无预警内容：列表页显示“当前暂无预警信息”，引导学生前往知识库了解日常防范知识。
包含用例	—
扩展用例	浏览知识库（UC-04，关联案例时条件触发）

5. UC-04：浏览诈骗案例知识库

表 3.5: UC-04 用例描述：浏览诈骗案例知识库

UC-04 浏览诈骗案例知识库	
用例编号	UC-04
用例名称	浏览诈骗案例知识库
参与者	普通学生 (Student)
前置条件	学生已登录系统；知识库中存在状态为“已发布”的条目
后置条件	无数据状态变更（只读浏览操作）
基本事件流	1. 学生在首页或顶部导航栏点击“知识库”，进入知识库列表页。 2. 系统展示所有已发布条目，默认按发布时间倒序排列；每条目呈现诈骗类型标签、标题、发布日期及摘要首句，每页展示 20 条，支持翻页浏览。 3. 学生可通过诈骗类型标签进行筛选，亦可在搜索框输入关键词（支持标题与摘要正文全文检索），列表实时刷新。 4. 学生点击某一条目，进入条目详情页，查看完整内容：诈骗类型标签、脱敏事件摘要、诈骗特征识别要点（条目列表形式）、防范建议、多发时间段参考、来源标注（本校上报案例或公安部通报）。 5. 详情页底部展示“相关推荐”——与当前条目同诈骗类型的其他已发布条目，最多展示 3 条，方便学生延伸阅读。
备选事件流	A1. 搜索无结果：系统显示“未找到相关内容”提示，并推荐当前热门诈骗类型标签供学生点击浏览，避免页面空白造成困惑。 A2. 从预警详情页跳转：学生点击预警内关联的案例编号链接，直接进入对应知识库条目详情页，跳过步骤 1 至步骤 3。 A3. 从测验错题推送跳转：学生答题错误后，系统推送对应知识库条目链接，点击后直接进入条目详情页，跳过步骤 1 至步骤 3。
包含用例	—
扩展用例	—

6. UC-05：参与安全意识测验

表 3.6: UC-05 用例描述：参与安全意识测验

UC-05 参与安全意识测验	
用例编号	UC-05
用例名称	参与安全意识测验
参与者	普通学生 (Student)
前置条件	学生已登录系统；题库中存在可用题目
后置条件	测验结果（得分、错题记录）保存至学生个人中心；管理员端测验统计数据同步更新
基本事件流 (随机练习模式)	1. 学生进入“安全意识测验”页面，选择随机练习模式。 2. 系统从题库中随机抽取 10 道题目（含情景判断题和知识点单选题混合）。 3. 学生逐题作答；每题提交后立即展示正确答案与解析。 4. 答错时，系统额外推送相关知识库条目链接，学生可点击跳转深入阅读。 5. 完成全部题目后，系统展示本次得分及错题汇总列表。 6. 测验结果自动保存至学生个人中心测验历史记录。
备选事件流	A1. 指定测验模式（与随机练习的差异）：入口由 UC-09 发布的站内通知触发；答题流程同基本事件流；与随机练习不同之处在于——测验有截止日期，学生在截止前可返回继续作答；完成后系统标记为“已完成”，结果纳入 UC-09 完成率报告。指定测验的发布、提醒、撤回等管理员侧动作详见 UC-09。 A2. 中途退出：随机练习模式中途退出，进度不保存，下次重新开始；指定测验中途退出则保留已答题目，可在截止前返回继续作答。
包含用例	—
扩展用例	浏览知识库（UC-04，答错时条件触发推送）

7. UC-06：审核事件

表 3.7: UC-06 用例描述：审核事件

UC-06 审核事件	
用例编号	UC-06
用例名称	审核事件
参与者	审核管理员 (Reviewer)
前置条件	管理员已登录系统；系统中存在状态为“待审核”的事件
后置条件	事件状态更新；操作人、操作时间、操作内容、操作前后状态变化均记录至审计日志；上报学生收到处理结果站内通知；若 24 小时内同一诈骗手法上报数量超过 3 条，系统自动向校级审核管理员推送聚合告警，建议发布预警
基本事件流	1. 管理员进入工作台首页，查看“待审核”事件列表（默认按提交时间倒序排列）。 2. 管理员使用筛选功能（按状态、诈骗类型、时间范围、涉案金额区间）或关键词搜索，定位目标事件。 3. 管理员点击事件条目进入详情页；系统记录首次打开时间，事件状态自动更新为“审核中”。 4. 管理员查看上报内容全文与证据材料（证据图片解密显示，操作记入审计日志）。 5. 管理员在内部备注栏填写处理备注（仅管理员可见）。 6. 管理员选择“录入案例库”处置操作：填写脱敏案例摘要（不含上报者个人信息），提交至知识库草稿队列；事件状态更新为“已处理”。 7. 系统记录完整审计日志条目，并向上报学生发送站内通知：“您的上报事件（编号：XXXX）已处理完毕”。
备选事件流	A1. 驳回事件：管理员选择“驳回”，系统强制要求填写驳回原因（字段不可为空），确认后状态更新为“已驳回”，驳回原因以站内通知形式告知上报学生。 A2. 联系上报人：管理员选择“联系上报人”，系统弹出二次确认框提示“查看联系方式将被记录至审计日志”，确认后解密显示上报者联系方式；若为匿名上报，系统拒绝显示任何联系方式，并提示管理员“如确需联系上报人，请通过 UC-11 备选 A2 的司法协助流程申请”。 A3. 标记转报警：管理员选择“标记转报警”，填写转报说明，事件状态更新为“已转报警”，系统记录转报时间与经办人。
包含用例	查看加密证据材料（文件解密访问）、记录审计日志
扩展用例	UC-08（管理员选择“录入案例库”时，作为《extend》关系触发）

8. UC-07：发布预警信息

表 3.8: UC-07 用例描述：发布预警信息

UC-07 发布预警信息	
用例编号	UC-07
用例名称	发布预警信息
参与者	审核管理员（Reviewer）
前置条件	管理员已登录系统；管理员已审核至少一条相关事件或掌握充分的预警依据
后置条件	预警进入“已发布”列表；目标范围内学生下次登录时首页顶部显示预警横幅并收到站内通知；发布行为记录至审计日志
基本事件流	1. 管理员进入预警管理页面，点击“发布新预警”。 2. 管理员填写预警标题（简明描述诈骗手法）。 3. 管理员填写预警正文，内容须包括：诈骗手法描述、识别要点（如何判断是否为诈骗）、防范建议（遭遇时应如何应对）。 4. 管理员选择性关联相关案件编号（关联后学生端可点击查看脱敏案例详情）。 5. 管理员选择预警等级：提示（蓝色）——某类诈骗近期抬头，日常宣教性质；警告（橙色）——近期已有明确受害案例；紧急（红色）——短时间内多名学生受害或涉案金额较大。 6. 管理员选择推送范围：按院系多选或选择“全校推送”。 7. 管理员点击“预览”查看预警在学生端的实际展示效果，确认无误后点击“确认发布”。 8. 系统记录发布人与发布时间，预警进入已发布列表，对目标学生生效。
备选事件流	A1. 紧急级额外推送：等级为“紧急”时，系统在站内通知之外，还向管理员配置的备用邮箱额外发送一条预警摘要邮件。 A2. 追加后续说明：预警发布后不可删除或修改；管理员可选择“追加后续说明”，在预警末尾补充处理结果，原始内容完整保留。 A3. 手动下线预警：预警过期后，管理员可将其移至历史预警列表，学生端首页不再展示横幅，但历史记录永久保留。
包含用例	发送站内通知、记录审计日志
扩展用例	—

9. UC-08：管理知识库条目

表 3.9: UC-08 用例描述：管理知识库条目

UC-08 管理知识库条目	
用例编号	UC-08
用例名称	管理诈骗案例知识库条目
参与者	审核管理员（Reviewer）
前置条件	管理员已登录系统；条目可独立新建，也可从 UC-06 第 6 步“录入案例库”扩展进入（自动带入事件基础信息）
后置条件	新条目首先进入“草稿”（DRAFT）状态；管理员提交审核后变为“待审核”（PENDING），由校级审核管理员审核通过后变为“已发布”（PUBLISHED），方在学生端展示；条目下线后变为“已下线”（OFFLINE）
基本事件流	1. 管理员进入知识库管理页面，点击“新建条目”（或在事件详情页选择“录入案例库”自动带入基础信息）。 2. 管理员填写条目完整信息：诈骗类型标签（与上报模块分类一致）、事件摘要（脱敏，不含受害者任何个人信息）、诈骗特征识别要点（条目列表形式）、防范建议、多发时间段参考、来源标注（“来源于本校上报案例”或“来源于公安部通报”）。 3. 4. 条目新建时默认为“草稿”（DRAFT）状态；管理员完成填写后点击“提交审核”，条目状态变为“待审核”（PENDING），进入校级审核管理员的审核队列。 5. 校级审核管理员在审核队列中查看待审条目，审核通过后条目状态由“待审核”（PENDING）变为“已发布”（PUBLISHED），学生端知识库页面即可检索到该条目；已发布条目可由管理员下线，状态变为“已下线”（OFFLINE），学生端不再展示但历史记录保留。
备选事件流	A1. 审核未通过：审核人填写驳回意见，条目状态回退为“草稿”（DRAFT），驳回意见以站内通知形式告知原管理员；原管理员修改后再次点击“提交审核”，条目重新进入“待审核”（PENDING）。 A2. 编辑已发布条目：管理员对已发布条目的修改需重新进入审核流程；审核期间学生端仍展示旧版本，审核通过后更新为新版本。
包含用例	记录审计日志
扩展用例	—

10. UC-09：维护题库与发起指定测验

表 3.10: UC-09 用例描述：维护题库与发起指定测验

UC-09 维护题库与发起指定测验	
用例编号	UC-09
用例名称	维护题库与发起指定测验
参与者	审核管理员（Reviewer）
前置条件	管理员已登录系统；题库中存在足量可用题目
后置条件	指定测验发布；目标学生收到测验通知；系统追踪完成情况并生成完成率报告
基本事件流	1. （题库维护子流程） 管理员进入“题库管理”页面，可对题目执行新增、编辑、停用操作：新增时填写题干、选项、正确答案、解析、关联诈骗类型与知识库条目（用于错题推送）、难度等级；编辑后版本递增，停用题目不再出现于抽题池；所有操作记入审计日志。 2. （发起测验子流程） 管理员进入测验管理页面，点击“发起指定测验”。 3. 管理员填写测验基本信息：测验名称、测验说明、题目范围（按诈骗类型标签筛选题目或手动指定题目）、题目数量（建议 10 至 20 题）。 4. 管理员设置目标参与范围（按院系多选或全校）及截止日期。 5. 管理员确认发布；系统向目标学生发送“新指定测验”站内通知。 6. 测验截止后，系统生成完成率报告（含各院系完成率、平均得分、未完成学生名单）供管理员下载。
备选事件流	A1. 截止前发提醒：系统在截止日期前 24 小时自动向未完成学生再次发送提醒通知。 A2. 测验撤回：测验发布后若需撤回，管理员填写撤回说明后可将测验下线；已完成的答题记录保留，未完成学生不再收到提醒。
包含用例	发送站内通知
扩展用例	—

11. UC-10：账号与权限管理

表 3.11: UC-10 用例描述：账号与权限管理

UC-10 账号与权限管理	
用例编号	UC-10
用例名称	账号与权限管理
参与者	系统管理员 (SysAdmin)
前置条件	系统管理员已登录系统, 具备 SysAdmin 权限
后置条件	账号或权限变更立即生效; 所有变更操作完整记录至审计日志
基本事件流	1. 系统管理员进入账号管理页面, 查看所有用户账号列表 (支持按角色、院系、账号状态筛选)。 2. 系统管理员选择目标账号并执行操作: • 创建新账号: 填写用户信息 (姓名、学号/工号、院系、角色), 提交后系统向新用户发送账号激活通知; • 停用账号: 将账号状态置为 “已停用”, 停用后该账号立即无法登录; • 角色变更: 修改账号的角色归属 (如将辅导员账号由 Student 升级为 Reviewer)。 3. 系统确认操作并记录至审计日志。
备选事件流	A1. 查阅审计日志: 系统管理员进入审计日志页面, 按操作类型、操作人、时间范围筛选查看日志; 日志不可编辑或删除, 任何角色均不例外。 A2. 司法协助查询匿名上报者身份: 系统管理员在特殊情况下须查看匿名上报者真实身份, 须填写查看原因 (如 “配合公安机关调查, 编号 XXXX”), 操作记录至审计日志, 同时向所有系统管理员账号发送告警通知。
包含用例	记录审计日志
扩展用例	查阅审计日志 (备选 A1)、司法协助查询 (备选 A2)

(三) 事件状态流转机制

1. 设计原则

事件状态机设计遵循以下三项原则:

- (1) 状态单调推进, 不可逆向回退: 事件一旦从 “待审核” 进入 “审核中”, 即不可回退至 “待审核”; 进入终态 (“已处理” “已驳回” “已转报警”) 后, 相关数据与状态记录永久封存, 不允许任何角色修改或删除, 以保障事件处理过程的完整审计追溯能力。
- (2) 状态变更与通知、审计强绑定: 每一次状态变更均自动触发两项副作用——向上报学生发送站内通知 (保证学生闭环知情)、向审计日志写入操作记录 (操作人、操作时间、变更前后状态、操作内容), 二者不可被业务代码绕过。
- (3) 终态处置可分支、不可并发: 从 “审核中” 出发的三条出路 (录入案例库、驳回、转报警) 相互排斥, 同一事件只能进入其中一种终态, 防止同一事件被多个管理员重复处置导致状态冲突。

2. 草稿状态的特殊处理

需要特别说明的是，UC-01 备选事件流 A4 提及的“草稿”状态不在本状态机管辖范围内。草稿是事件提交前的本地暂存形态，仅在上报学生本人的“草稿箱”中可见，不进入审核队列，不分配案件编号，不触发任何管理员侧通知；学生可对草稿进行任意次数的编辑或删除。只有当学生在 UC-01 第 6 步点击“提交”并通过格式校验后，事件才正式进入图 3.2 所示的状态机，从“待审核”开始向后流转。

3. 终态后的二次行为

事件进入终态后，业务上仍可能产生以下“事后行为”，但这些行为不改变原事件状态：

- 已驳回事件的重新上报：学生若对驳回原因有补充材料，须以新事件形式重新提交（生成新的案件编号），原已驳回事件保持终态不变，系统在新事件详情页关联展示原驳回事件编号，便于审核员追溯。
- 已处理事件追加预警：审核管理员可基于已处理事件发起 UC-07 发布预警，但该操作产生的预警是独立实体，与原事件状态机解耦。
- 已转报警事件的处置反馈：线下报警结果由系统管理员通过 UC-10 在事件附注栏手动登记（操作记入审计日志），仅用于补充信息展示，不引发状态变化。

4. 状态流转图

上报事件在系统内依照严格的状态机进行流转，每次状态变更均由明确的业务操作触发，并自动向上报学生发送站内通知、同步写入审计日志。图 3.2 展示了完整的状态转移关系。



图 3.2: 诈骗事件上报状态流转图

各状态的触发条件与系统行为如表 3.12 所示。

表 3.12: 诈骗事件状态说明表

状态	枚举值	触发条件	系统行为	学生端可见描述
待审核	PENDING	学生提交表单并通过格式校验	生成唯一案件编号；向责任审核管理员推送待处理站内通知	已收到，等待审核
审核中	REVIEWING	审核管理员首次打开事件详情页	记录首次查看时间截至审计日志；事件从待审核队列移至进行中	正在处理中
已处理	RESOLVED	管理员完成核实并选择录入案例库	脱敏摘要进入知识库草稿队列；向上报学生发送处理完成站内通知	已处理完毕
已驳回	REJECTED	管理员填写驳回原因后确认驳回	驳回原因以站内通知形式推送给上报学生；操作记入审计日志	事件已关闭（附驳回说明）
已转报警	TRANSFERRED	管理员选择标记转报警并填写转报说明	记录转报时间与经办人至审计日志；向上报学生发送转报通知	已转交相关部门处理

四、 非功能性需求

本章我们将从准确性与可靠性、性能与及时性、安全性、易用性与美观性、兼容性、可维护性与标准性、先进性与可扩展性、合规性八个维度对平台的非功能性需求进行描述。

(一) 准确性与可靠性

- 1. 事件上报表单须对所有必填字段进行完整性校验，对日期、金额、联系方式等结构化字段进行格式校验，确保进入审核队列的数据不存在明显缺失或格式错误。
- 2. 系统自动生成的案件编号须全局唯一，唯一性由数据库唯一约束保障，而非仅依赖应用层逻辑。
- 3. 事件状态流转须严格遵循第三章定义的状态机，禁止出现跳跃流转或因并发写入导致的状态不一致；关键状态变更须在数据库事务中原子执行，确保“状态更新—审计日志写入—通知推送触发”三步操作的最终一致性。
- 4. 预警信息的推送范围（按院系/全校）须与管理员配置完全一致，不得出现漏推或越范围推送。
- 5. 知识库条目的诈骗类型标签须与上报模块的分类体系保持一一对应，不得出现分类名称不一致或孤立标签。

(二) 性能与及时性

表 4.1: 系统响应时间需求

操作类型	目标响应时间	说明
页面首屏加载（校内访问）	≤ 3 s	含静态资源加载
事件上报表单提交	≤ 5 s	含证据文件写入
预警列表 / 知识库列表查询	≤ 2 s	普通查询
全文关键词搜索	≤ 3 s	文本内容检索
站内通知推送可见延迟	≤ 10 s	事件提交后至通知出现

平台各类操作的响应时间目标如表 4.1 所示。在处理时效层面，有以下要求：

- 学生提交事件后，审核管理员端工作台须在 10 s 内展示新待办条目。
- 审核管理员对每条待审核事件的平均处理时长不超过 48 小时，系统通过超时提醒机制辅助保障该目标，超时后自动向管理员发送催办通知。
- 预警信息确认发布后，目标学生登录时须在首页顶部立即可见预警横幅；对于“紧急”级预警，须额外向管理员配置的备用邮箱发送摘要邮件。

(三) 安全性

1. 身份认证与会话管理

- (1) 平台须对接学校统一身份认证系统，不提供独立注册入口；未登录状态下访问任意业务地址须自动跳转至认证页面。
- (2) 会话标识须设置安全属性，防止被客户端脚本读取或跨站点携带。
- (3) 用户连续 30 分钟无操作后，系统须自动失效会话，下次访问须重新认证。
- (4) 用户主动退出后，系统须同步调用统一认证系统的登出端点，确保单点注销生效，此后直接访问业务地址须重新触发认证。

2. 权限控制

- (1) 系统采用基于角色的访问控制（RBAC）模型，各角色权限边界严格按照权限矩阵执行；越权访问须在服务端接口层拦截并返回拒绝访问状态码，不得仅依赖前端控件的显示与隐藏实现访问控制。
- (2) 匿名上报者真实身份须在数据库层独立存储，仅系统管理员在填写查看原因并记录审计后方可解密访问。

- (3) 证据文件须采用行业公认的强加密算法进行加密存储，只有经过授权的服务端接口才能获取解密内容。

3. 传输安全与审计

- (1) 生产部署时须全站启用传输加密协议，禁用已知存在安全风险的早期协议版本。
- (2) 审计日志须覆盖登录/登出、事件状态变更、证据文件查看、匿名身份解密、账号变更、预警发布、知识库审核等所有敏感操作；每条日志须记录操作人标识、时间戳、来源 IP、操作类型、对象标识及变更前后状态。
- (3) 知识库条目须经脱敏处理，不得包含任何可识别个人身份的信息；平台不得向任何第三方商业机构共享或出售用户数据。

(四) 易用性与美观性

1. 学生完成诈骗事件上报的操作步骤简单：从点击“我要上报”到收到提交成功确认，符合低门槛上报的系统目标。
2. 表单校验须提供即时的字段级错误提示，明确指出问题字段及修正方式，错误字段以醒目颜色高亮标注，不得仅显示“提交失败”等笼统提示。
3. 当网络异常导致上报提交失败时，系统须将草稿暂存并提示用户，使其可在个人中心草稿箱中继续编辑。
4. 所有列表页在无数据时须显示空状态说明文字及引导操作，不得展示空白页面；当统一认证系统不可用时，须展示友好提示页面，而非浏览器默认错误页。
5. 平台整体视觉风格须保持统一，包括色彩体系、字体规范、间距规则与图标风格；预警信息以差异化颜色标识等级——提示级蓝色、警告级橙色、紧急级红色，颜色语义贯穿列表页与详情页保持一致。
6. 重要操作按钮须在视觉层级上突出；空状态页面、加载中状态、操作成功/失败反馈页面须提供完整的视觉设计，不得以纯文字或浏览器默认样式替代。

(五) 兼容性

1. 平台须在近三个大版本内的主流桌面浏览器中正常运行，核心功能无明显布局错乱或交互异常。
2. 平台须采用响应式设计，兼容主流移动端浏览器，核心按钮与表单元素不发生重叠或溢出。

3. 平台对接学校统一身份认证系统须遵循校方现有协议版本，在校方现有认证基础设施不作任何改造的前提下完成集成。
4. 系统导出的数据文件须采用通用开放格式，确保可在常见办公软件中直接打开，无需额外转换。

（六）可维护性与标准性

1. 配置外部化：数据库连接参数、外部服务地址、密钥等环境相关参数须通过配置文件或环境变量注入，不得硬编码于源代码中。
2. 接口规范：后端接口设计须遵循统一的资源型风格，使用标准协议方法表达操作语义，响应体统一采用结构化文本格式，时间字段统一使用开放标准格式；接口须具备自动生成的可读文档。
3. 编码规范：后端代码须遵循业界主流的编码规范，前端代码须遵循业界主流的编码规范；关键业务逻辑须有清晰的注释说明；项目须提供本地开发环境搭建文档，使新成员可在 30 分钟内完成环境初始化并启动服务。
4. 单元测试：核心业务逻辑须具备单元测试覆盖，包括事件状态流转合法性校验、权限拦截逻辑、上报表单字段校验规则，测试套件须能通过自动化命令执行并全部通过。
5. 数据库版本管理：数据库结构变更须使用版本化工具进行管理，数据库对象统一命名风格；每次迭代的结构变更须有对应迁移脚本并纳入版本控制。

（七）先进性与可扩展性

1. 系统架构须支持前后端分离部署，前端与后端可独立构建、独立部署；后端服务须能够在标准化的运行环境中启动与运行。
2. 系统应支持通过配置实现水平扩容，无须修改代码；新增服务实例时，平台整体功能不受影响。
3. 应用服务层须设计为无状态，用户会话须存储于外部共享存储而非应用进程本地内存，以保证后续水平扩展的可行性；各核心业务模块须在代码层面保持独立，通过定义明确的服务接口交互，避免强耦合。
4. 系统须提供可扩展点，支持在不修改核心代码的前提下接入以下能力：
 - 新增通知渠道（当前仅实现站内通知与邮件推送）；
 - 对外数据导出接口（供未来对接外部系统使用）；

- 辅助分类建议逻辑（当前分类由用户手动选择）。

5. 业务规则配置项须通过参数化方式实现，不得硬编码，以便在不修改代码的前提下灵活调整运营策略。

(八) 合规性

1. 平台建设须参照以下法规的原则性要求：《中华人民共和国反电信网络诈骗法》（2022 年）、《中华人民共和国个人信息保护法》（2021 年）、《中华人民共和国网络安全法》（2017 年）。具体体现在：个人信息最小化收集、匿名上报隐私保护、敏感信息加密存储、操作行为全程可追溯。
2. 知识库与预警内容须完成个人信息脱敏，符合个人信息保护法中关于匿名化处理的要求；平台不得向任何第三方商业机构共享或出售用户数据。
3. 系统须防范开放式 Web 应用安全项目中与业务相关的常见漏洞类型，上线前须完成安全自查并整改已知问题。

(九) 非功能性需求汇总

表 4.2 对上述各维度的核心指标进行汇总。

表 4.2: 非功能性需求核心指标汇总

维度	指标	目标值
准确性与可靠性	案件编号唯一性	数据存储层唯一机制保障
准确性与可靠性	状态流转一致性	事务原子执行，禁止跳跃
性能与及时性	页面首屏加载时间	≤ 3 s
性能与及时性	上报表单提交响应	≤ 5 s
性能与及时性	事件平均处理时长	≤ 48 h
安全性	传输加密协议	须启用，禁用早期版本
安全性	文件加密强度	行业公认强加密算法
安全性	越权访问响应	服务端拦截
易用性与美观性	上报操作步骤数	≤ 3 步
易用性与美观性	预警等级视觉区分	三级差异化颜色标识
兼容性	桌面浏览器支持	近三个大版本内的主流浏览器
可维护性与标准性	接口文档	可自动生成
可维护性与标准性	配置项硬编码	不允许
先进性与可扩展性	会话存储方式	外部共享存储，无本地状态
先进性与可扩展性	水平扩容方式	配置化，不修改代码
合规性	知识库内容脱敏	不含任何可识别个人身份信息

五、 数据需求

数据是业务的载体，亦是系统设计的根基。本章在第三章功能性需求与第四章非功能性需求的基础上，从数据建模的视角对系统进行进一步刻画——回答系统在运行过程中需要保存什么数据、这些数据如何组织、它们之间存在何种关系以及如何在数据层面保障业务规则与安全合规四个核心问题。本章的产出将作为下一阶段数据库逻辑设计与物理设计的直接输入。

（一） 数据需求概述

1. 编写目的

本章的编写目的可归纳为以下四点：

- （1） 识别核心数据资产：从功能用例中抽取所有需要持久化的信息项，对其进行实体化封装，避免在后续设计阶段出现数据遗漏或重复定义。
- （2） 建立数据语义基线：通过数据字典明确每个字段的类型、长度、约束与业务含义，使开发、测试、运维各团队对数据的理解保持一致，消除沟通歧义。
- （3） 支撑非功能需求落地：将第四章中关于安全性、可靠性、可维护性的定性表述，进一步细化为数据库层面可验证、可执行的约束规则（如唯一性约束、加密存储字段、审计字段等）。
- （4） 为后续设计提供输入：作为概要设计阶段绘制类图、设计数据访问层以及编写数据库迁移脚本的直接依据，确保数据模型在系统全生命周期内保持稳定可演进。

2. 数据建模方法

平台数据建模采用“实体关系建模结合数据字典与完整性约束规约”三层递进式方法。三层之间的关系如下：

- 第一层实体关系建模：以扩展 ER 图（兼容 UML 类图风格）刻画系统中的核心数据实体及其关联，回答“有什么、彼此如何关联”的问题，是数据模型的宏观骨架。
- 第二层数据字典：对每个实体的字段、类型、约束、默认值与业务说明进行结构化描述，回答“每个实体内部存什么、怎么存”的问题，是数据模型的微观细节。
- 第三层完整性约束规约：在前两层基础上，对实体完整性、参照完整性、用户自定义完整性进行集中规约，回答“什么样的数据组合是合法的”的问题，是数据模型的业务护栏。

三层模型并非孤立存在，而是与第三章功能用例一一对应：每一个用例的执行都将引发数据实体的状态变更，每一条状态变更都受到完整性约束的校验。表 5.1 给出了核心用例与其所操作的主要数据实体之间的对应关系，便于读者交叉对照。

表 5.1: 核心用例与主要数据实体对应关系

用例编号	用例名称	所涉主要数据实体
UC-00	CAS 单点登录	User、Session、AuditLog
UC-01	上报诈骗事件	FraudReport、Evidence、AnonymousMapping、ReportDraft、Notification
UC-02	查看个人中心与上报追踪	FraudReport、StateTransition、Notification
UC-03	浏览预警信息	WarningNotice、WarningTarget、WarningRead
UC-04	浏览诈骗案例知识库	KnowledgeEntry、FraudType
UC-05	参与安全意识测验	Quiz、Question、QuizAttempt、AnswerRecord
UC-06	审核事件	FraudReport、StateTransition、Evidence、AuditLog
UC-07	发布预警信息	WarningNotice、WarningTarget、AuditLog
UC-08	管理知识库条目	KnowledgeEntry、KnowledgeEntryHistory、AuditLog
UC-09	发起指定测验	Quiz、Question、QuizQuestion、Notification
UC-10	账号与权限管理	User、Role、RolePermission、SystemConfig、AuditLog

3. 数据分类

为提升数据模型的可读性与可维护性，本平台将所有数据实体按业务语义划分为 五大业务域，各域内部高内聚、域之间通过明确的外键关系低耦合协作。五大业务域的整体构成如表 5.2 所示。

表 5.2: 平台数据五大业务域划分

业务域	实体数	域内主要实体与职责定位
用户与权限域	5	User (用户)、Department (院系)、Role (角色)、Permission (权限)、RolePermission (角色权限关联)；承载身份认证与 RBAC 权限模型
事件上报域	6	FraudReport (事件主表)、FraudType (诈骗类型字典)、Evidence (证据文件)、StateTransition (状态变更历史)、AnonymousMapping (匿名映射)、ReportDraft (上报草稿)；承载平台核心业务流
预警与知识库域	5	WarningNotice (预警)、WarningTarget (推送目标)、WarningRead (阅读记录)、KnowledgeEntry (知识库条目)、KnowledgeEntryHistory (条目版本历史)；承载预警发布与知识沉淀
安全教育域	5	Quiz (测验)、Question (题库)、QuizQuestion (测验题目关联)、QuizAttempt (答题记录)、AnswerRecord (答题明细)；承载情景化安全教育
系统支撑域	4	Notification (站内通知)、AuditLog (审计日志)、Session (会话)、SystemConfig (系统参数)；承载系统级横切关注点

五大业务域共包含 25 个核心数据实体，它们共同构成平台运行所依赖的完整数据视图。下文 (二) 节将通过 ER 图整体呈现这些实体之间的关联，(三) 节将逐域展开数据字典。

(二) 主要数据实体及其关系

1. 实体识别清单

依据业务域划分，对全部数据实体进行统一编号，结果如表 5.3 所示。表中“主键策略”一栏说明了该实体的主键生成方式，将在第 (四) 节中进一步阐述其设计理由。

表 5.3: 平台核心数据实体清单

编号	实体名称（中文/英文）	主键策略	业务角色定位
E01	用户 / User	雪花 ID	系统所有操作的责任主体
E02	院系 / Department	自增 ID	组织架构的最小单元，承载推送范围
E03	角色 / Role	自增 ID	RBAC 模型中的角色实体
E04	权限 / Permission	自增 ID	RBAC 模型中的权限实体
E05	角色权限关联 / RolePermission	复合主键	角色—权限多对多关系实现
E06	诈骗事件上报 / FraudReport	雪花 ID	平台最核心的业务实体
E07	诈骗类型 / FraudType	自增 ID	八类诈骗手法的字典表
E08	证据文件 / Evidence	雪花 ID	上报附件的元数据，文件实体加密存储
E09	状态变更历史 / StateTransition	雪花 ID	事件状态机的不可变变更日志
E10	匿名映射 / AnonymousMapping	雪花 ID	隔离匿名上报者真实身份的独立表
E11	上报草稿 / ReportDraft	雪花 ID	用户提交前的本地暂存数据
E12	预警信息 / WarningNotice	雪花 ID	管理员发布的预警实体
E13	预警推送目标 / WarningTarget	复合主键	预警与院系（或全校）的关联
E14	预警阅读记录 / WarningRead	复合主键	学生阅读预警的留痕
E15	知识库条目 / KnowledgeEntry	雪花 ID	脱敏后的反诈知识沉淀
E16	条目版本历史 / KnowledgeEntryHistory	雪花 ID	知识库条目的版本快照
E17	测验 / Quiz	雪花 ID	测验实例（随机练习或指定测验）
E18	题目 / Question	雪花 ID	题库中的可复用题目
E19	测验题目关联 / QuizQuestion	复合主键	测验与题目的多对多关系
E20	答题记录 / QuizAttempt	雪花 ID	学生参加某次测验的总记录
E21	答题明细 / AnswerRecord	雪花 ID	单题作答详情
E22	站内通知 / Notification	雪花 ID	系统向用户推送的通知消息
E23	审计日志 / AuditLog	雪花 ID	所有敏感操作的不可篡改留痕
E24	会话 / Session	UUID	CAS 登录后的服务器端会话
E25	系统参数 / SystemConfig	自增 ID	系统级可配置参数

2. 系统整体 ER 图

将上述 25 个实体之间的关联关系统一呈现，形成本平台的整体 ER 图，如图 5.1 所示。图中实体使用矩形框表示，关系通过带基数标注的连线表达；为提高可读性，已按业务域对实体进行了空间聚类（同一业务域的实体在视觉上集中分布），跨域关联线特别加粗以提示读者注意域间数据流向。

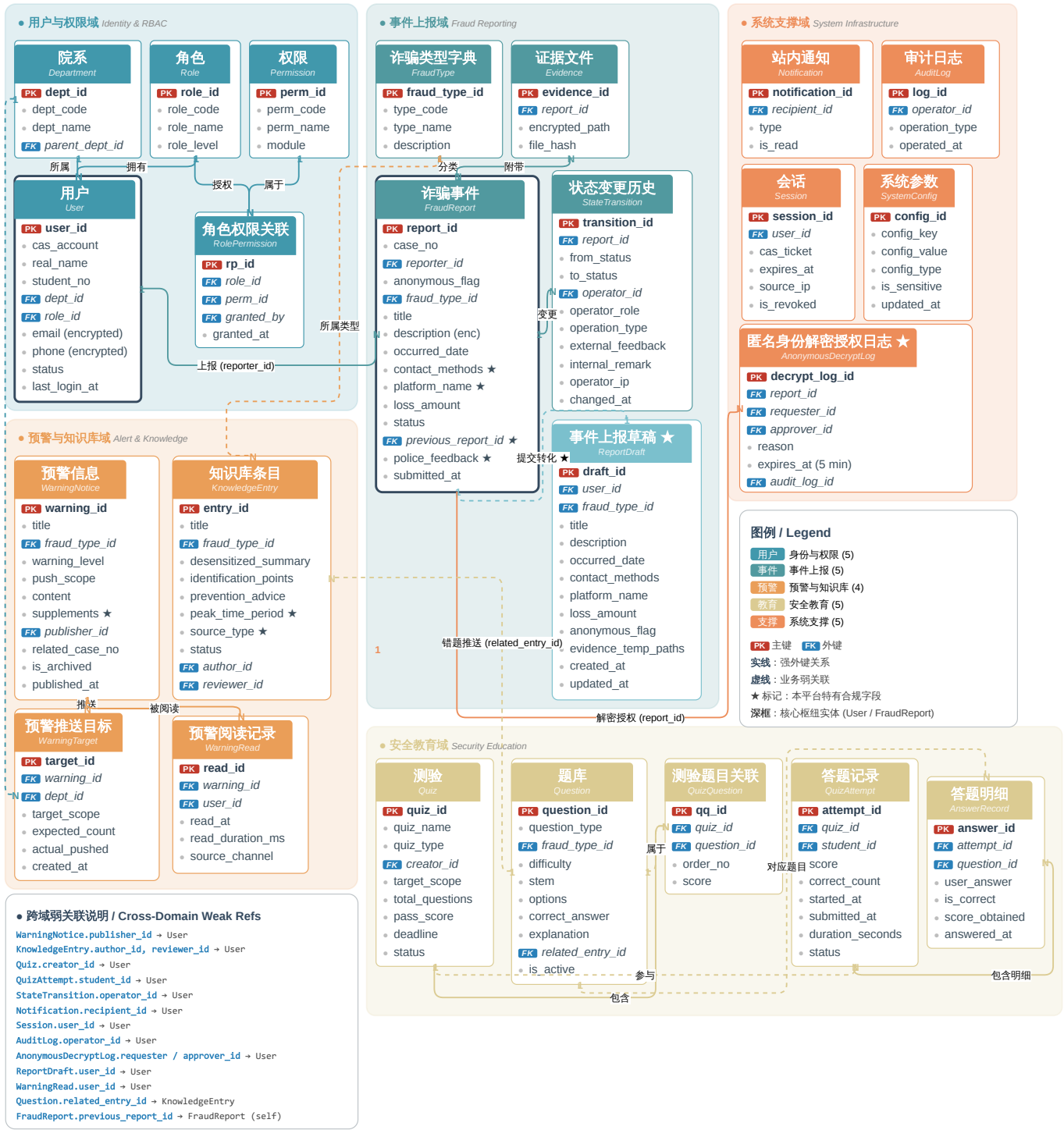


图 5.1: 系统整体 ER 图

图片上一些关系按 FK 字段理论上存在，但为了保持视觉简洁，选择在右下角的“跨域弱关联说明”块中用文字列表统一说明，没有在图中画箭头表示。

3. 核心实体关系详细说明

ER 图所蕴含的关系语义需要进一步以自然语言加以阐释，以便读者准确理解关系背后的业务规则。表 5.4 列出了平台中 18 条核心实体关系的完整说明。其中“参照完整性”一栏说明了当父实

体被删除或主键变更时，子实体的级联策略——这是后续数据库物理设计阶段确定外键约束行为的依据。

表 5.4: 平台核心实体关系说明表

编号	关系（父实体—子实体）	基数	业务含义	参照策略
R01	Department —User	1:N	一个院系下属多名学生与教职工	RESTRICT
R02	Role —User	1:N	一个角色被多名用户持有	RESTRICT
R03	Role —RolePermission — Permission	M:N	RBAC 模型中角色与权限的多对多关系	CASCADE
R04	User —FraudReport（实名 上报）	1:N	一名学生可提交多条实名上报；删除受 RESTRICT 限制	RESTRICT
R05	FraudReport — AnonymousMapping	1:1	仅匿名上报事件存在该映射；用于隔离真实身份	RESTRICT
R06	FraudType —FraudReport	1:N	每条上报必须归属某一诈骗类型	RESTRICT
R07	FraudReport —Evidence	1:N	一条上报最多关联 10 张证据图	CASCADE
R08	FraudReport — StateTransition	1:N	一条上报伴随多次状态变更，全部留痕	RESTRICT
R09	User —ReportDraft	1:N	一名用户可保留多份未提交草稿	CASCADE
R10	User（Reviewer） — WarningNotice	1:N	审核管理员发布多条预警	RESTRICT
R11	WarningNotice — WarningTarget —Department	M:N	预警可推送至若干院系或全校	CASCADE
R12	WarningNotice — WarningRead —User	M:N	学生阅读预警的留痕	CASCADE
R13	FraudType — KnowledgeEntry	N:1	知识库条目按诈骗类型归类	RESTRICT
R14	KnowledgeEntry — KnowledgeEntryHistory	1:N	条目每次发布形成新版本快照	RESTRICT
R15	KnowledgeEntry —Question	1:N	错题推送依据题目关联的知识条目	SET NULL
R16	Quiz —QuizQuestion — Question	M:N	题目可被多份测验复用	CASCADE
R17	Quiz —QuizAttempt —User	M:N	学生参加某次测验形成一条 attempt	RESTRICT
R18	QuizAttempt — AnswerRecord —Question	M:N	单次答题中各题作答详情	CASCADE

上表中尚未涉及的若干“系统级关联”——如 User 到 AuditLog 的关系（一名操作者产生多条审计日志）、User 到 Notification 的关系（一名收件人对应多条通知）等——由于其语义直观、无业务规则歧义，不在此处单独罗列，但在数据字典中通过外键字段予以明确。

4. 关键业务规则约束

数据模型不仅是字段的容器，更是业务规则的载体。本节归纳由 ER 模型层面直接保障的五条关键业务规则：

- (1) 事件状态流转单调性：FraudReport 表的 current_status 字段配合 StateTransition 表的不可

删除特性，共同保障事件状态只能按3.2所规定的方向单调推进，杜绝逆向回退或跳跃流转。任何状态变更必须先在 StateTransition 中插入记录，再更新 FraudReport 的当前状态字段，二者在同一数据库事务内原子完成。

- (2) **案件编号全局唯一性**：FraudReport 表的 case_no 字段（格式为 年份-院系代码-流水号）由数据库唯一约束保障全局唯一，并配合分布式 ID 生成器避免高并发场景下的编号冲突。即使应用层逻辑出现缺陷，唯一约束也会在数据存储层兜底拦截。
- (3) **匿名上报身份隔离**：当 FraudReport 表的 anonymous_flag = TRUE 时，reporter_id 字段在主表中存储为 NULL，真实上报者标识被加密存储于独立的 AnonymousMapping 表，且该表的访问受到独立权限控制与审计跟踪（详见 五 节）。这种“主表脱敏 + 映射隔离”的设计在数据库层面实现了匿名性的物理保障。
- (4) **诈骗类型分类一致性**：FraudType 作为字典表被 FraudReport、KnowledgeEntry、Question 三个核心实体共同引用，避免了同一分类在不同模块出现命名漂移；当业务方需要新增或调整分类时，仅需修改 FraudType 一处。
- (5) **审计日志不可变性**：AuditLog 表在数据库层面禁止 UPDATE 与 DELETE 操作，只允许 INSERT，并通过数据库触发器或权限分离的方式强制执行。即使是系统管理员也不能修改历史审计记录，从而保障合规审计的可信度。

5. 核心业务数据流图

为进一步揭示数据在系统内部的流动路径，本节给出诈骗事件上报全流程的数据流转图。

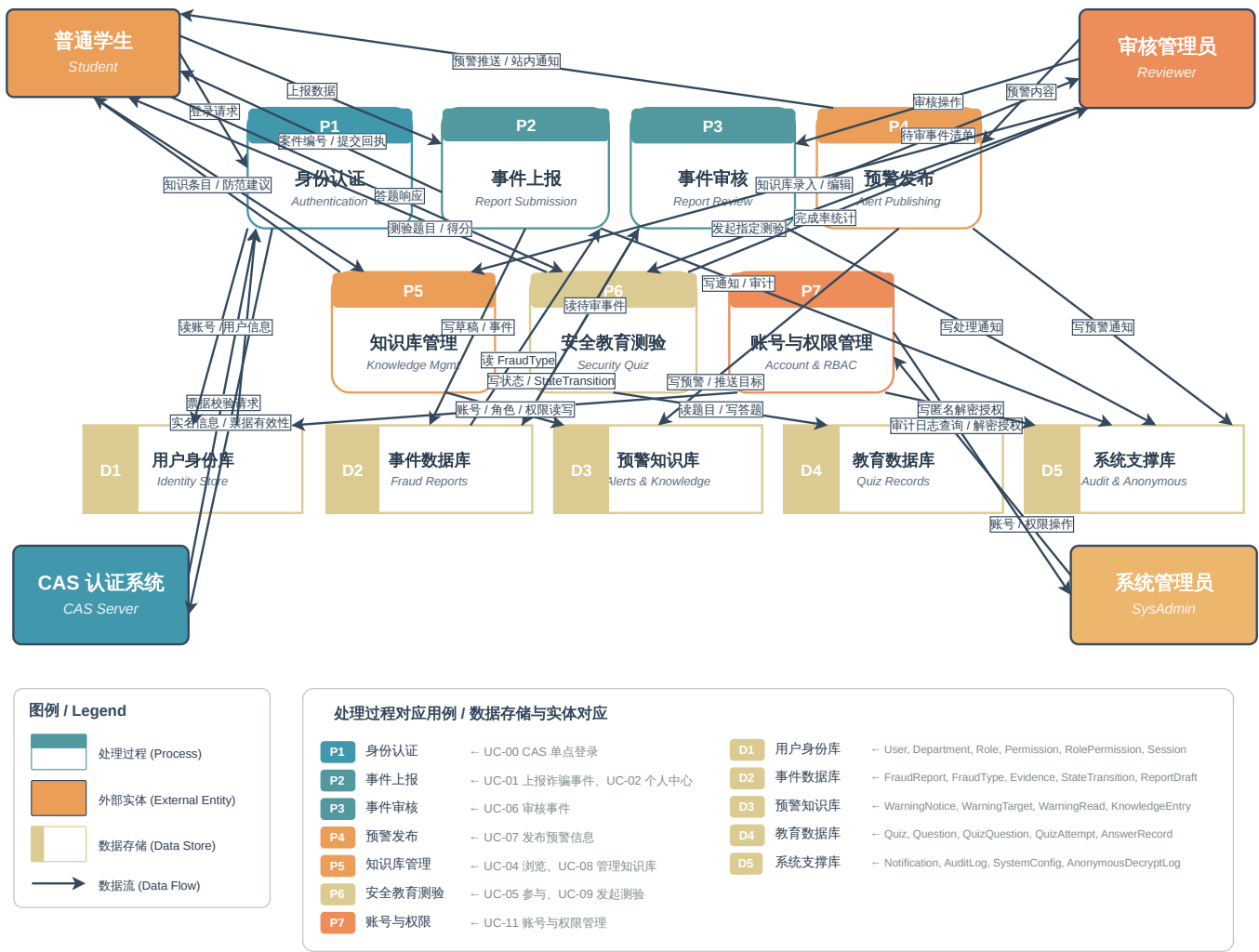


图 5.2: 诈骗事件上报全流程数据流图（一级图）

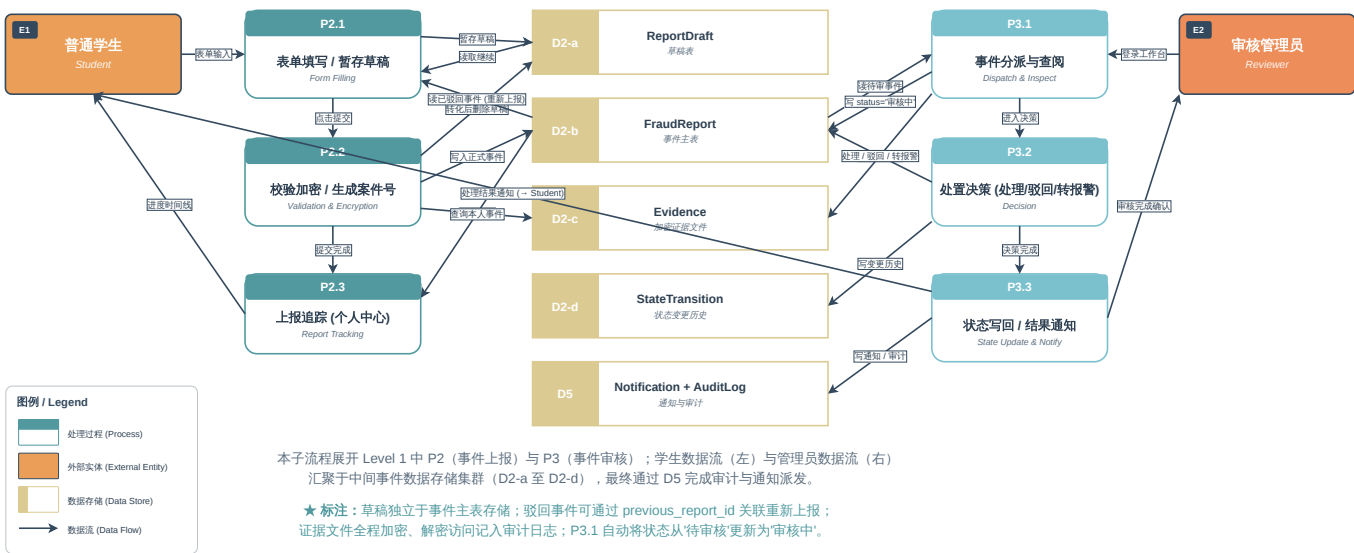


图 5.3: 诈骗事件上报全流程数据流图（二级图——内部细节）

其中，图 5.2 展示了审核管理员与系统之间的外部数据交互；图 5.3 进一步展开系统内部各模

块之间的数据流动路径，涉及上报草稿暂存、表单校验、案件编号分配、证据加密落盘、待审核入队、状态变更记录、通知推送及审计日志写入等环节。

(三) 关键数据字典

数据字典是对每一个数据实体内部字段的精确定义，是开发与测试阶段不可或缺的参考依据。本节按划定的五大业务域逐一展开。每张数据字典表统一包含字段名、类型与长度、约束（PK 主键 / FK 外键 / NN 非空 / UQ 唯一 / IDX 索引）、默认值与业务说明五列。

1. 用户与权限域

用户与权限域承载平台所有用户的身份信息以及基于角色的访问控制（RBAC）模型。该域是其余所有业务域的基础，几乎每一个业务实体都通过外键引用 User 表以记录“谁创建、谁审核、谁负责”。

(1) User —— 用户表（E01）

表 5.5: User 用户表数据字典

字段名	类型与长度	约束	默认值	业务说明
user_id	BIGINT	PK, NN	雪花算法	系统内部用户唯一标识
cas_account	VARCHAR(32)	UQ, NN	—	CAS 学号或工号
real_name	VARCHAR(64)	NN	—	用户真实姓名
department_id	BIGINT	FK, NN	—	所属院系，外键引用 Department
role_id	INT	FK, NN	1（学生）	用户角色，外键引用 Role
email_encrypted	VARBINARY(255)	—	NULL	AES-256 加密的邮箱
phone_encrypted	VARBINARY(64)	—	NULL	AES-256 加密的手机号
avatar_url	VARCHAR(255)	—	NULL	头像图片访问地址
status	TINYINT	NN, IDX	1	1= 正常 / 2= 已停用 / 3= 已注销
created_at	DATETIME	NN	CURRENT_TIMESTAMP	账号创建时间
last_login_at	DATETIME	—	NULL	最近一次登录时间
last_login_ip	VARCHAR(45)	—	NULL	最近一次登录来源 IP（兼容 IPv6）

(2) Department —— 院系表（E02）

表 5.6: Department 院系表数据字典

字段名	类型与长度	约束	默认值	业务说明
dept_id	BIGINT	PK, NN	自增	院系唯一标识
dept_code	VARCHAR(16)	UQ, NN	—	院系编码，用于案件编号生成
dept_name	VARCHAR(64)	NN	—	院系中文全称
parent_dept_id	BIGINT	FK	NULL	上级院系（支持多层次组织）
dept_level	TINYINT	NN	1	院系层级，1= 学院 / 2= 专业
sort_order	INT	NN	0	显示排序权重

(3) Role ——角色表 (E03)

表 5.7: Role 角色表数据字典

字段名	类型与长度	约束	默认值	业务说明
role_id	INT	PK, NN	自增	角色唯一标识
role_code	VARCHAR(32)	UQ, NN	—	角色编码，取值 STUDENT / REVIEWER / SYS_ADMIN；审核管理员的院系级与校级区分由 role_level 字段表达
role_name	VARCHAR(64)	NN	—	角色中文名称
role_level	TINYINT	NN	1	角色层级；当 role_code=REVIEWER 时，1= 院系级、2= 校级；其它角色固定为 1
description	VARCHAR(255)	—	NULL	角色职责描述
created_at	DATETIME	NN	CURRENT_TIMESTAMP	创建时间

(4) Permission ——权限表 (E04)

表 5.8: Permission 权限表数据字典

字段名	类型与长度	约束	默认值	业务说明
permission_id	INT	PK, NN	自增	权限唯一标识
permission_code	VARCHAR(64)	UQ, NN	—	权限编码，如 REPORT:CREATE、WARNING:PUBLISH
permission_name	VARCHAR(64)	NN	—	权限中文描述
resource_type	VARCHAR(32)	NN	—	资源类型，如 REPORT / WARNING / KB
action_type	VARCHAR(16)	NN	—	操作类型，如 CREATE / READ / UPDATE / DELETE
description	VARCHAR(255)	—	NULL	权限详细说明

(5) RolePermission ——角色权限关联表 (E05)

表 5.9: RolePermission 角色权限关联表数据字典

字段名	类型与长度	约束	默认值	业务说明
role_id	INT	PK, FK, NN	—	角色 ID
permission_id	INT	PK, FK, NN	—	权限 ID
granted_at	DATETIME	NN	CURRENT_TIMESTAMP	授予时间
granted_by	BIGINT	FK	NULL	授予人（系统管理员）

2. 事件上报域

事件上报域是平台最核心的业务领域，本节六张数据字典表共同支撑了“上报—审核—状态流转—证据加密—匿名隔离”全流程。

(1) FraudReport —— 诈骗事件上报表 (E06)

FraudReport 是平台业务中心实体, 每一条上报对应表中一条主记录, 其状态字段 current_status 严格遵循3.2 定义的状态机进行流转。

表 5.10: FraudReport 诈骗事件上报表数据字典

字段名	类型与长度	约束	默认值	业务说明
report_id	BIGINT	PK, NN	雪花算法	上报记录唯一标识
case_no	VARCHAR(32)	UQ, NN, IDX	—	案件编号, 格式: YYYY-DEPTCODE-NNNNNN
reporter_id	BIGINT	FK	NULL	实名上报者 ID; 匿名上报时为 NULL
anonymous_flag	TINYINT	NN	0	0= 实名 / 1= 匿名
fraud_type_id	INT	FK, NN	—	诈骗类型, 外键引用 FraudType
occurred_date	DATE	NN	—	事件发生日期
description	TEXT	NN	—	事件经过文字描述 (建议 ≥ 200 字)
loss_amount	DECIMAL(10,2)	NN	0.00	涉及金额 (元); 0 表示仅遭遇未受损
contact_methods	VARCHAR(64)	NN	—	诈骗方式 (多选, 逗号分隔)
platform_name	VARCHAR(128)	—	NULL	涉及平台或应用名称
current_status	VARCHAR(16)	NN, IDX	PENDING	状态枚举: PENDING / REVIEWING / RESOLVED / REJECTED / TRANSFERRED
submitted_at	DATETIME	NN, IDX	CURRENT_TIME_STAMP	提交时间
current_reviewer_id	BIGINT	FK	NULL	当前负责审核员 ID
last_updated_at	DATETIME	NN	CURRENT_TIME_STAMP	最后更新时间

(2) FraudType —— 诈骗类型字典表 (E07)

FraudType 是 FraudReport、KnowledgeEntry、Question 共同引用的字典表, 其内容在系统初始化时按第三章 UC-01 中定义的八类诈骗手法预填充。

表 5.11: FraudType 诈骗类型字典表数据字典

字段名	类型与长度	约束	默认值	业务说明
fraud_type_id	INT	PK, NN	自增	诈骗类型 ID
type_code	VARCHAR(32)	UQ, NN	—	类型编码, 如 BRUSH_REWARD、FAKE_POLICE
type_name	VARCHAR(64)	NN	—	类型中文名称
type_description	VARCHAR(255)	—	NULL	类型简要说明, 用于辅助上报判断
sort_order	INT	NN	0	显示排序权重
is_active	TINYINT	NN	1	是否启用, 停用后不再出现于下拉选项

(3) Evidence —— 证据文件表 (E08)

Evidence 仅存储证据图片的元数据，文件实体本身经 AES-256 加密后存储于独立的对象存储服务，不在数据库中保存。

表 5.12: Evidence 证据文件表数据字典

字段名	类型与长度	约束	默认值	业务说明
evidence_id	BIGINT	PK, NN	雪花算法	证据记录唯一标识
report_id	BIGINT	FK, NN, IDX	—	所属事件 ID
original_filename	VARCHAR(255)	NN	—	上传时原始文件名
encrypted_file_path	VARCHAR(512)	NN	—	加密文件在对象存储中的路径
file_hash_sha256	CHAR(64)	NN	—	文件 SHA-256 哈希，用于完整性校验
aes_key_id	VARCHAR(64)	NN	—	加密所用 AES 密钥版本标识
file_size	INT	NN	—	文件大小（字节），不超过 5 MB
mime_type	VARCHAR(32)	NN	—	文件 MIME 类型，如 image/jpeg
uploaded_at	DATETIME	NN	CURRENT_TIMESTAMP	上传时间

(4) StateTransition ——状态变更历史表 (E09)

StateTransition 是事件状态机的不可变变更日志，每一次状态转移都插入一条新记录，记录从何状态来、到何状态去、由谁操作、何时操作、对外反馈了什么、内部备注了什么。该表既支撑 UC-02 学生端的处理进展展示，也为审计追溯提供原始数据。

表 5.13: StateTransition 状态变更历史表数据字典

字段名	类型与长度	约束	默认值	业务说明
transition_id	BIGINT	PK, NN	雪花算法	变更记录唯一标识
report_id	BIGINT	FK, NN, IDX	—	关联事件 ID
from_status	VARCHAR(16)	NN	—	变更前状态；首次记录为 NEW
to_status	VARCHAR(16)	NN	—	变更后状态
operator_id	BIGINT	FK, NN	—	操作人 ID（系统自动操作记为系统账号）
operation_type	VARCHAR(32)	NN	—	操作类型，如 SUBMIT、OPEN_DETAIL、RESOLVE、REJECT、TRANSFER_POLICE
internal_remark	TEXT	—	NULL	内部备注（仅管理员可见）
external_feedback	TEXT	—	NULL	对外反馈说明（学生可见）
source_ip	VARCHAR(45)	NN	—	操作来源 IP
transitioned_at	DATETIME	NN, IDX	CURRENT_TIMESTAMP	变更发生时间

(5) AnonymousMapping ——匿名映射表 (E10)

AnonymousMapping 是实现匿名上报隐私保护的关键基础设施。当用户选择匿名上报时，系统将真实身份从主表 FraudReport 中剥离，转而以加密形式存储于本表中，访问本表受到比一般业务表更严格的权限控制。

表 5.14: AnonymousMapping 匿名映射表数据字典

字段名	类型与长度	约束	默认值	业务说明
mapping_id	BIGINT	PK, NN	雪花算法	映射记录唯一标识
report_id	BIGINT	UQ, FK, NN	—	关联事件 ID（一对一）
encrypted_reporter_id	VARBINARY(128)	NN	—	加密后的真实上报者 ID
encryption_key_version	VARCHAR(32)	NN	—	加密密钥版本（支持密钥轮转）
created_at	DATETIME	NN	CURRENT_TIMESTAMP	映射创建时间

(6) ReportDraft —— 上报草稿表（E11）

ReportDraft 用于支撑 UC-01 备选事件流 A4 中的“网络异常自动暂存草稿”机制以及 UC-02 中的“草稿续填”扩展。草稿数据不进入审核队列，不生成案件编号，仅在用户本人的草稿箱中可见。

表 5.15: ReportDraft 上报草稿表数据字典

字段名	类型与长度	约束	默认值	业务说明
draft_id	BIGINT	PK, NN	雪花算法	草稿唯一标识
owner_id	BIGINT	FK, NN, IDX	—	草稿所属用户 ID
draft_data	JSON	NN	—	表单各字段的暂存内容
last_saved_at	DATETIME	NN	CURRENT_TIMESTAMP	最近保存时间
expires_at	DATETIME	NN	—	自动过期时间（默认保留 30 天）

3. 预警与知识库域

预警与知识库域承载平台从“被动应对”到“主动防控”的能力延伸：预警信息将经核实的诈骗手法第一时间触达目标学生群体，知识库则将历史案例沉淀为可检索的反诈知识资产。

(1) WarningNotice —— 预警信息表（E12）

表 5.16: WarningNotice 预警信息表数据字典

字段名	类型与长度	约束	默认值	业务说明
warning_id	BIGINT	PK, NN	雪花算法	预警唯一标识
title	VARCHAR(128)	NN	—	预警标题
content	TEXT	NN	—	预警正文（含手法、识别要点、防范建议）
warning_level	TINYINT	NN, IDX	—	1= 提示（蓝）/ 2= 警告（橙）/ 3= 紧急（红）
related_case_no	VARCHAR(32)	—	NULL	关联案件编号（可选）
publisher_id	BIGINT	FK, NN	—	发布人（审核管理员）
push_scope	VARCHAR(16)	NN	—	FULL_SCHOOL / DEPARTMENT
published_at	DATETIME	NN, IDX	CURRENT_TIMESTAMP	发布时间
status	VARCHAR(16)	NN	ONLINE	ONLINE / OFFLINE
expires_at	DATETIME	—	NULL	自动下线时间（紧急级建议设置）

(2) WarningTarget —— 预警推送目标表 (E13)

当 push_scope=DEPARTMENT 时，每条预警可关联多个院系，形成多对多关系。

表 5.17: WarningTarget 预警推送目标表数据字典

字段名	类型与长度	约束	默认值	业务说明
warning_id	BIGINT	PK, FK, NN	—	预警 ID
dept_id	BIGINT	PK, FK, NN	—	目标院系 ID
added_at	DATETIME	NN	CURRENT_TIMESTAMP	关联建立时间

(3) WarningRead —— 预警阅读记录表 (E14)

表 5.18: WarningRead 预警阅读记录表数据字典

字段名	类型与长度	约束	默认值	业务说明
warning_id	BIGINT	PK, FK, NN	—	预警 ID
user_id	BIGINT	PK, FK, NN	—	阅读用户 ID
read_at	DATETIME	NN	CURRENT_TIMESTAMP	阅读时间戳

(4) KnowledgeEntry —— 知识库条目表 (E15)

KnowledgeEntry 存储已脱敏的反诈知识条目，是 UC-04 的核心数据载体。每个条目具有版本号字段，配合 KnowledgeEntryHistory 实现版本管理。

表 5.19: KnowledgeEntry 知识库条目表数据字典

字段名	类型与长度	约束	默认值	业务说明
entry_id	BIGINT	PK, NN	雪花算法	条目唯一标识
title	VARCHAR(128)	NN, IDX	—	条目标题
fraud_type_id	INT	FK, NN, IDX	—	诈骗类型分类
desensitized_summary	TEXT	NN	—	脱敏后的事件摘要
identification_points	TEXT	NN	—	诈骗特征识别要点
prevention_advice	TEXT	NN	—	防范建议
peak_periods	VARCHAR(255)	—	NULL	多发时间段参考
source_type	VARCHAR(16)	NN	—	SCHOOL / NATIONAL（来源标注）
source_reference	VARCHAR(255)	—	NULL	来源具体说明（如关联案件编号）
status	VARCHAR(16)	NN, IDX	DRAFT	DRAFT / PENDING / PUBLISHED / OFFLINE
version	INT	NN	1	版本号，每次发布递增
author_id	BIGINT	FK, NN	—	作者（审核管理员）
reviewer_id	BIGINT	FK	NULL	校级审核人
created_at	DATETIME	NN	CURRENT_TIMESTAMP	创建时间
published_at	DATETIME	—	NULL	首次发布时间

(5) KnowledgeEntryHistory —— 条目版本历史表（E16）

表 5.20: KnowledgeEntryHistory 条目版本历史表数据字典

字段名	类型与长度	约束	默认值	业务说明
history_id	BIGINT	PK, NN	雪花算法	历史记录唯一标识
entry_id	BIGINT	FK, NN, IDX	—	关联条目 ID
version	INT	NN	—	该快照对应的版本号
content_snapshot	JSON	NN	—	该版本完整内容快照
modified_by	BIGINT	FK, NN	—	修改人 ID
modified_at	DATETIME	NN	CURRENT_TIMESTAMP	修改时间

4. 安全教育域

安全教育域支撑 UC-05 与 UC-09 两个用例，将传统的“被动接收宣教”转化为“情景化互动测验 + 错题知识推送”的闭环。

(1) Quiz —— 测验表（E17）

表 5.21: Quiz 测验表数据字典

字段名	类型与长度	约束	默认值	业务说明
quiz_id	BIGINT	PK, NN	雪花算法	测验唯一标识
quiz_name	VARCHAR(128)	NN	—	测验名称
quiz_type	VARCHAR(16)	NN	—	RANDOM= 随机练习 / ASSIGNED= 指定测验
description	VARCHAR(512)	—	NULL	测验说明
creator_id	BIGINT	FK	NULL	发起人；随机练习无发起人
target_scope	VARCHAR(16)	—	NULL	目标范围（仅指定测验）
question_count	INT	NN	10	题目数量
start_at	DATETIME	—	NULL	开始时间（仅指定测验）
deadline	DATETIME	—	NULL	截止时间（仅指定测验）
status	VARCHAR(16)	NN	ACTIVE	ACTIVE / WITHDRAWN / ENDED
created_at	DATETIME	NN	CURRENT_TIMESTAMP	创建时间

(2) Question ——题库表 (E18)

表 5.22: Question 题库表数据字典

字段名	类型与长度	约束	默认值	业务说明
question_id	BIGINT	PK, NN	雪花算法	题目唯一标识
question_type	VARCHAR(16)	NN	—	SCENARIO= 情景判断 / SINGLE_CHOICE= 单选
fraud_type_id	INT	FK, IDX	NULL	关联诈骗类型，便于按主题筛选
stem	TEXT	NN	—	题干
options_json	JSON	NN	—	选项 JSON 数组
correct_answer	VARCHAR(16)	NN	—	正确答案标识（如 A / B / C / D）
explanation	TEXT	—	NULL	答案解析
related_entry_id	BIGINT	FK	NULL	错题推送的目标知识条目
difficulty_level	TINYINT	NN	2	1= 简单 / 2= 中等 / 3= 困难
is_active	TINYINT	NN	1	是否启用

(3) QuizQuestion ——测验题目关联表 (E19)

表 5.23: QuizQuestion 测验题目关联表数据字典

字段名	类型与长度	约束	默认值	业务说明
quiz_id	BIGINT	PK, FK, NN	—	测验 ID
question_id	BIGINT	PK, FK, NN	—	题目 ID
sort_order	INT	NN	0	题目在测验中的顺序

(4) QuizAttempt ——答题记录表 (E20)

表 5.24: QuizAttempt 答题记录表数据字典

字段名	类型与长度	约束	默认值	业务说明
attempt_id	BIGINT	PK, NN	雪花算法	答题记录唯一标识
quiz_id	BIGINT	FK, NN, IDX	—	测验 ID
student_id	BIGINT	FK, NN, IDX	—	学生 ID
score	INT	—	NULL	得分（百分制；未提交时为 NULL）
started_at	DATETIME	NN	CURRENT_TIMESTAMP	开始作答时间
submitted_at	DATETIME	—	NULL	提交时间
status	VARCHAR(16)	NN	IN_PROGRESS	IN_PROGRESS / SUBMITTED / EXPIRED

(5) AnswerRecord ——答题明细表 (E21)

表 5.25: AnswerRecord 答题明细表数据字典

字段名	类型与长度	约束	默认值	业务说明
record_id	BIGINT	PK, NN	雪花算法	答题明细记录唯一标识
attempt_id	BIGINT	FK, NN, IDX	—	关联答题记录
question_id	BIGINT	FK, NN	—	题目 ID
user_answer	VARCHAR(64)	—	NULL	用户答案
is_correct	TINYINT	NN	0	0= 错误 / 1= 正确
time_spent_seconds	INT	—	NULL	该题作答耗时（秒）

5. 系统支撑域

系统支撑域承载横切于所有业务的系统级功能：通知推送、审计留痕、会话管理与参数配置。这些实体不属于业务核心，但是平台稳定运行不可或缺的“基础设施”。

(1) Notification ——站内通知表 (E22)

表 5.26: Notification 站内通知表数据字典

字段名	类型与长度	约束	默认值	业务说明
notification_id	BIGINT	PK, NN	雪花算法	通知唯一标识
recipient_id	BIGINT	FK, NN, IDX	—	收件人 ID
type	VARCHAR(32)	NN, IDX	—	通知类型, 如 REPORT_RESOLVED、WARNING_PUSH、QUIZ_ASSIGNED
title	VARCHAR(128)	NN	—	通知标题
content	VARCHAR(512)	NN	—	通知正文
related_object_type	VARCHAR(32)	—	NULL	关联业务对象类型
related_object_id	BIGINT	—	NULL	关联业务对象 ID
is_read	TINYINT	NN, IDX	0	0= 未读 / 1= 已读
created_at	DATETIME	NN	CURRENT_TIME STAMP	创建时间
read_at	DATETIME	—	NULL	阅读时间

(2) AuditLog —— 审计日志表 (E23)

AuditLog 是平台合规运行的“黑匣子”，覆盖第四章安全性需求中规定的所有敏感操作。该表在数据库层面禁止 UPDATE 与 DELETE 操作，仅允许追加写入。

表 5.27: AuditLog 审计日志表数据字典

字段名	类型与长度	约束	默认值	业务说明
log_id	BIGINT	PK, NN	雪花算法	日志唯一标识
operator_id	BIGINT	FK, NN, IDX	—	操作人 ID
operation_type	VARCHAR(64)	NN, IDX	—	操作类型, 如 LOGIN、VIEW_EVIDENCE、DECRYPT_ANONYMOUS
object_type	VARCHAR(32)	NN	—	操作对象类型
object_id	VARCHAR(64)	NN	—	操作对象标识
before_state	JSON	—	NULL	变更前状态快照
after_state	JSON	—	NULL	变更后状态快照
source_ip	VARCHAR(45)	NN	—	来源 IP
user_agent	VARCHAR(255)	—	NULL	客户端 UA 信息
operated_at	DATETIME(3)	NN, IDX	CURRENT_TIME STAMP	操作时间（毫秒精度）

(3) Session —— 会话表 (E24)

表 5.28: Session 会话表数据字典

字段名	类型与长度	约束	默认值	业务说明
session_id	CHAR(36)	PK, NN	UUID	会话唯一标识
user_id	BIGINT	FK, NN, IDX	—	关联用户 ID
cas_ticket	VARCHAR(128)	—	NULL	CAS 服务票据缓存
created_at	DATETIME	NN	CURRENT_TIMESTAMP	会话创建时间
last_active_at	DATETIME	NN	CURRENT_TIMESTAMP	最近活跃时间（用于超时判定）
expires_at	DATETIME	NN, IDX	—	失效时间（默认 30 分钟无操作）
source_ip	VARCHAR(45)	NN	—	登录来源 IP
user_agent	VARCHAR(255)	—	NULL	客户端 UA

(4) SystemConfig ——系统参数表（E25）

表 5.29: SystemConfig 系统参数表数据字典

字段名	类型与长度	约束	默认值	业务说明
config_id	INT	PK, NN	自增	参数唯一标识
config_key	VARCHAR(64)	UQ, NN	—	参数键名
config_value	TEXT	NN	—	参数值
value_type	VARCHAR(16)	NN	STRING	STRING / INT / BOOLEAN / JSON
description	VARCHAR(255)	—	NULL	参数说明
updated_by	BIGINT	FK	NULL	最近更新人
updated_at	DATETIME	NN	CURRENT_TIMESTAMP	最近更新时间

(四) 数据完整性约束

数据完整性是数据库正确反映业务现实的根本保证。本节分别从实体完整性、参照完整性与用户自定义完整性三个层面，给出本平台数据模型层面的完整性规约。

1. 实体完整性

实体完整性要求每个数据实体的主键必须非空且全局唯一。本平台主键设计采用差异化策略，针对不同实体的访问模式选用最合适的主键生成方式：

- (1) 雪花算法 (Snowflake ID): 用于业务核心实体——FraudReport、Evidence、Notification、AuditLog、KnowledgeEntry 等。雪花算法生成的 64 位整数 ID 时间有序、分布式无冲突，且不暴露业务数

据规模，避免攻击者通过 ID 推断系统数据量。

- (2) **数据库自增 (AUTO_INCREMENT)**：用于字典表与少量低频写入实体——Department、Role、Permission、FraudType、SystemConfig。这些实体写入频率低、不存在分布式生成需求，自增 ID 简单高效。
- (3) **UUID**：用于 Session 表。会话标识不应可预测，UUID v4 随机生成的特性可有效防止会话固定攻击。
- (4) **复合主键**：用于多对多关联表——RolePermission、QuizQuestion、WarningTarget、WarningRead。复合主键既保证唯一性，又天然防止重复关联。

此外，业务上具备唯一含义的字段须建立唯一索引 (UQ)，形成“业务唯一键”，与“主键”形成双层保护。表 5.30 列出了平台中需要建立业务唯一键的字段。

表 5.30: 业务唯一键字段汇总

所属表	唯一字段	业务唯一性来源
User	cas_account	学校 CAS 账号天然唯一
Department	dept_code	院系编码全校唯一
Role	role_code	角色编码业务约定唯一
Permission	permission_code	权限编码业务约定唯一
FraudType	type_code	类型编码业务约定唯一
FraudReport	case_no	案件编号生成时强制唯一
AnonymousMapping	report_id	一对一关系，确保单条事件只有一条映射
SystemConfig	config_key	参数键名业务约定唯一

2. 参照完整性

参照完整性通过外键约束实现，保证子表中引用的父表记录始终存在。本平台外键级联策略采用“按业务语义定级联行为”的差异化设计：

- (1) **RESTRICT (限制删除)**：当父记录被引用时，禁止删除父记录。适用于绝大多数业务关系，例如：用户被事件引用时不可硬删除（应改为软删除）；诈骗类型被事件或题目引用时不可删除；案件在状态变更后不可删除。这是默认且最安全的策略。
- (2) **CASCADE (级联删除)**：父记录删除时，子记录一并删除。仅用于“父子关系紧密、子记录脱离父记录无意义”的场景，例如：事件被允许彻底删除时，其证据元数据、状态变更记录（仅在测试环境）随之删除；测验删除时其题目关联随之删除。生产环境对核心业务表禁用此策略。
- (3) **SET NULL (置空)**：父记录删除时，子记录的外键置 NULL。适用于“弱关联”场景，如题目关联的知识库条目被下线时，题目本身仍然有效，仅将关联清空。

3. 用户自定义完整性

用户自定义完整性是业务规则在数据库层面的具体落地。本平台对关键业务字段定义了如下 **CHECK** 约束与触发器规则，归纳如表 5.31 所示。

表 5.31: 用户自定义完整性约束汇总

所属字段	约束类型	规则说明
FraudReport.case_no	格式约束	必须匹配正则 <code>^\d{4}-[A-Z0-9]{2,8}-\d{6}\$</code>
FraudReport.current_status	枚举约束	取值集合 {PENDING, REVIEWING, RESOLVED, REJECTED, TRANSFERRED}
FraudReport.loss_amount	范围约束	≥ 0 , 且 $\leq 99,999,999.99$
FraudReport (状态流转)	触发器规则	不允许从终态 (RESOLVED / REJECTED / TRANSFERRED) 回退到任何非终态
FraudReport (时间一致性)	触发器规则	<code>submitted_at ≤ last_updated_at</code>
FraudReport (匿名一致性)	触发器规则	当 <code>anonymous_flag=1</code> 时 <code>reporter_id</code> 必须为 NULL; 当 <code>anonymous_flag=0</code> 时 <code>reporter_id</code> 必须非 NULL
Evidence.file_size	范围约束	$0 < \text{file_size} \leq 5\,242\,880$ 字节 (5 MB)
Evidence.mime_type	枚举约束	取值集合 {image/jpeg, image/png, image/gif}
WarningNotice.warning_level	枚举约束	取值集合 {1, 2, 3}
WarningNotice.push_scope	枚举约束	取值集合 {FULL_SCHOOL, DEPARTMENT}
QuizAttempt.score	范围约束	$0 \leq \text{score} \leq 100$
QuizAttempt (时间一致性)	触发器规则	<code>started_at ≤ submitted_at</code>
AuditLog (不可变性)	表级权限	数据库账号配置仅授予 INSERT 与 SELECT 权限, 无 UPDATE/DELETE
Session (自动失效)	调度任务	每 10 分钟扫描清理 <code>expires_at < NOW()</code> 的会话记录

(五) 数据安全与隐私需求

电信诈骗事件天然涉及大量敏感个人信息——受害者姓名、联系方式、损失金额、证据材料等。一旦数据泄露，将对学生造成二次伤害，并使平台失去公信力。因此，数据安全与隐私保护必须从数据模型设计阶段即予以系统性规划，而非作为事后补救措施。

1. 敏感字段分级

参照《个人信息保护法》对个人信息分类分级的总体要求，平台对所有字段按敏感度划分为三级，并采取差异化的存储与访问策略，如表 5.32 所示。

表 5.32: 数据敏感度分级表

等级	级别名称	典型字段示例	存储与访问策略
L1	公开级	FraudType、KnowledgeEntry (已发布)、WarningNotice (公开内容)	明文存储；全角色可读
L2	内部级	FraudReport.description、StateTransition.internal_remark、AuditLog 大部分字段	明文存储；权限受控访问；操作记入审计
L3	高敏级	User.phone_encrypted、User.email_encrypted、AnonymousMapping.encrypted_reporter_id、Evidence 加密文件	字段级加密存储；仅授权接口可解密；访问全程审计且需填写访问原因

2. 加密存储要求

针对 L3 高敏级数据，平台采用以下加密存储策略：

- (1) **字段级加密**：User 表的 `phone_encrypted` 与 `email_encrypted` 字段采用 AES-256-GCM 算法加密后以 `VARBINARY` 类型存储；密钥不存储于数据库内部，而由独立的密钥管理服务（KMS）托管。
- (2) **文件加密**：Evidence 关联的证据图片实体在写入对象存储前以 AES-256-CBC 加密，加密所用数据密钥（DEK）每文件独立生成，DEK 本身由 KMS 主密钥（KMK）加密后存储于 `aes_key_id` 字段标识的位置。该“信封加密”模式即使存储介质被物理获取，也无法直接解读文件内容。
- (3) **用户密码不落地**：本平台对接 CAS 单点登录，不存储用户密码任何形式的副本（包括哈希值），完全交由学校 CAS 系统管理；这从根源上消除了密码泄露的风险面。
- (4) **密钥轮转**：所有 L3 字段的加密密钥须支持在线轮转，通过 `encryption_key_version` 字段记录使用的密钥版本，历史数据在密钥过期后由后台任务批量重新加密。

3. 匿名上报数据隔离机制

匿名上报是本平台对学生隐私权的核心承诺，其数据层实现采用“主表脱敏 + 映射隔离 + 受控解密”的三层架构。具体规则如下：

- (1) **主表脱敏**：FraudReport 表的 `reporter_id` 字段在匿名上报场景下显式存储为 `NULL`，并在数据库触发器层面强制保证：当 `anonymous_flag = 1` 时 `reporter_id` 必须为 `NULL`，反之必须非 `NULL`。这一约束使得即使应用代码出现缺陷，也无法将真实身份意外写入主表。
- (2) **独立映射表**：真实身份以加密形式存储于独立的 `AnonymousMapping` 表中。该表不被任何业务功能直接引用，仅有系统管理员的“司法协助查询”功能可在记录访问原因后进行解密读取（对应 UC-10 备选事件流 A2）。
- (3) **物理权限隔离**：`AnonymousMapping` 表在数据库账号层面与主业务表使用不同的访问账号——业务应用账号无任何访问权限，仅有专用的“敏感信息访问”账号才能查询，且该账号的连接受到独立的网络层访问控制。
- (4) **解密访问全审计**：每一次对 `AnonymousMapping` 的解密读取都必须在 `AuditLog` 中插入一条 `operation_type = DECRYPT_ANONYMOUS` 的日志，记录操作人、原因、时间、来源 IP，并同时向所有系统管理员发送告警通知，形成“事中通报、事后追溯”的双重监督。

4. 数据保留与销毁策略

数据生命周期管理是合规运行的另一关键。本平台对各类数据的保留期与销毁策略规约如表 5.33 所示，遵循“业务必需即保留、过期即销毁、关键数据永久存档”的原则。

表 5.33: 数据保留与销毁策略

数据类别	保留期限	销毁方式与说明
审计日志 (AuditLog)	永久保留	不允许删除；每年归档一次至冷存储
事件主数据 (FraudReport 终态)	永久保留	进入终态后封存；通过软删除标记屏蔽展示，物理记录保留
证据文件 (Evidence)	与事件主数据同步	事件归档时同步归档；密钥同步迁移
上报草稿 (ReportDraft)	30 天	后台任务每日清理 expires_at < NOW() 的草稿
会话数据 (Session)	过期后 24 小时	后台任务每 10 分钟扫描清理过期会话
站内通知 (Notification)	90 天	已读通知保留 30 天后归档；未读通知保留 90 天
用户账号 (注销后)	立即脱敏，6 个月 后物理删除	注销时所有 L2/L3 字段脱敏，业务关联保留至 6 个月期满
匿名映射 (AnonymousMapping)	与事件主数据同步	事件归档时一并归档；解密密钥单独备份并加密保管

(六) 数据量估算与索引设计建议

为后续容量规划与性能优化奠定基础，本节基于学校实际情况对各核心数据实体的数据量级进行估算，并就高频查询场景给出索引设计建议。

1. 数据规模估算

按学校在读学生 2 万人、教职工 500 人、平台 5 年使用周期的参考规模，对核心实体的数据量进行如下估算（结果汇总于表 5.34）：

- **User**：约 2.05 万条静态记录；每年新增/注销约 5 000 条（按入学/毕业自然替换计算）。
- **FraudReport**：参考公开数据，估算每年上报量约 5 000 条，5 年累计约 2.5 万条。考虑到平台推广带动上报积极性提升，预留 50% 增长空间，按 4 万条规划。
- **Evidence**：按平均每条上报 3 张证据图估计，5 年累计约 12 万条元数据，对应文件存储约 600 GB（按平均每张 1 MB 估算）。
- **StateTransition**：每条事件平均经历 3 次状态变更，5 年累计约 12 万条。
- **Notification**：日均通知量约 1 000 条，5 年累计约 180 万条。
- **AuditLog**：高频写入实体，覆盖所有敏感操作。日均写入约 5 000 条，5 年累计约 900 万条，需重点关注存储优化与归档策略。

- **Session**：在线峰值约 5 000 条；过期清理后表内长期保持低水位（万条以下）。
- **KnowledgeEntry**：累计千条量级，访问频繁但数据量小。
- **QuizAttempt** 与 **AnswerRecord**：以年均 3 次全校测验计算，5 年累计 attempt 约 30 万条、answer_record 约 300 万条。

表 5.34: 核心数据实体 5 年数据量估算

实体	5 年累计量级	设计影响
User	~ 2.5 万条	普通规模，无特殊设计
FraudReport	~ 4 万条	小规模，关注状态字段索引
Evidence（元数据）	~ 12 万条	文件实体走对象存储
StateTransition	~ 12 万条	按 report_id 分区可选
Notification	~ 180 万条	历史通知按时间分区归档
AuditLog	~ 900 万条	重点优化：按月分区 + 冷归档
KnowledgeEntry	~ 千条	高读低写，建议引入查询缓存
QuizAttempt	~ 30 万条	按学期归档可选
AnswerRecord	~ 300 万条	与 QuizAttempt 联动归档

2. 关键索引设计建议

基于上述数据量估算与第三章功能用例中识别的高频查询场景，建议在数据库层建立如表 5.35 所示的关键索引。索引命名统一采用 idx_<table>_<columns> 格式以便维护。

表 5.35: 关键索引设计建议

所属表	索引字段（建议名）	加速的查询场景
FraudReport	(current_status, submitted_at) idx_report_status_time	UC-06 待审核队列按状态 + 时间排序加载
FraudReport	(reporter_id, submitted_at) idx_report_reporter_time	UC-02 个人中心“我的上报”时间线
FraudReport	(current_reviewer_id, current_status) idx_report_reviewer_status	审核员工作台“我处理中的事件”筛选
StateTransition	(report_id, transitioned_at) idx_st_report_time	UC-02 事件处理进展时间线展示
Evidence	(report_id) idx_evidence_report	事件详情页加载证据列表
Notification	(recipient_id, is_read, created_at) idx_notif_user_read_time	个人中心通知中心未读优先展示
AuditLog	(operator_id, operated_at) idx_audit_op_time	系统管理员按操作人筛选审计日志
AuditLog	(object_type, object_id, operated_at) idx_audit_object	按某事件追溯其完整操作历史
KnowledgeEntry	(fraud_type_id, status, published_at) idx_kb_type_status_time	UC-04 知识库按类型筛选 + 发布时间排序
KnowledgeEntry	全文索引 (title, desensitized_summary) ft_kb_search	UC-04 知识库关键词全文检索
WarningNotice	(status, published_at) idx_warning_status_time	UC-03 在线预警按发布时间倒序加载
QuizAttempt	(student_id, quiz_id) idx_attempt_student_quiz	UC-09 指定测验完成情况查询

3. 数据归档策略

针对 AuditLog 与 Notification 等高写入量、低查询频次的实体，平台采用“热数据在线、温数据近线、冷数据离线”的三层归档策略：

- 热数据（最近 3 个月）：保留在主数据库内，使用 SSD 存储介质，支持实时查询。
- 温数据（3 个月至 3 年）：迁移至按月分区的归档表（仍位于主数据库实例），查询时通过分区裁剪减少扫描量；存储介质可下沉至 HDD。
- 冷数据（3 年以上）：导出为列式压缩文件（如 Parquet）存储于对象存储服务，按需通过外部查询工具访问；预计存储成本可降低至热数据的 1/10 以下。

归档操作由后台调度任务在每月初的低峰时段自动执行，全过程记入 AuditLog，并通过校验和确保归档前后数据完整一致。归档不会改变数据本身的合规属性——审计日志的“永久保留”承诺始终成立。

六、约束与假设

需求分析的最终目的是为后续设计与实现工作提供清晰、可执行的输入。然而，任何系统的建设都不可能在真空中进行——它必然受到既有技术体系、组织管理制度、法律法规以及一系列前置条件的限制。本章在前五章功能性、非功能性与数据需求的基础上，对“校园电信诈骗上报与预警平台”在落地实施过程中所面临的各类约束予以集中梳理，并对系统设计所依赖的若干前提假设予以显式声明。本章旨在回答以下三个核心问题：第一，系统“必须遵守什么”——即技术与业务层面的硬性边界；第二，系统“不必处理什么”——即由约束条件天然排除在系统范围外的情形；第三，系统“默认相信什么”——即设计与实现工作所依赖的前提假设。明确以上三点，可有效防止后续设计阶段因边界模糊导致的方案误判，并为项目验收阶段的责任划分提供依据。

（一）技术约束

技术约束指系统在技术选型、开发实现及部署运维过程中所必须遵守的硬性条件。本平台的技术约束主要源自三个方面：南开大学信息化建设的统一规范、现有信息化基础设施的兼容要求，以及项目自身在课程作业范围内的可行性边界。

1. 开发语言与框架约束

- （1）后端开发语言固定为 **Python 3.11+**：选择 Python 3.11 及以上版本作为后端开发语言，充分利用其在 3.11 版本中引入的性能优化与异常组特性。Python 在 Web 后端、数据处理与安全脚本三类场景中具有完整的生态支持，可在课程作业的开发周期内显著降低实现成本。后端不得引入 Python 2.x 系列代码，亦不得在同一项目中混用其它后端语言。
- （2）后端框架固定为 **FastAPI 0.110+**：业务服务统一基于 FastAPI 构建，依托其原生支持的异步处理、Pydantic 数据校验与自动生成的 OpenAPI 文档能力，与第四章“接口须具备自动生成的可读文档”的可维护性需求形成天然契合；持久层采用 SQLAlchemy 2.x（配合 Alembic 进行数据库版本管理）作为统一 ORM，不得在同一项目中混用 Django ORM、Peewee 等其它 ORM 框架，以保证代码风格统一。Web 服务器统一采用 Uvicorn 配合 Gunicorn 的多进程部署模式。
- （3）前端技术栈采用 **Vue 3 + TypeScript**：前端统一采用 Vue 3 配合 TypeScript 进行开发，UI 组件库统一选用 Element Plus，以保证视觉风格与交互模式在全平台范围内的一致性；微信小程序端如实施，则采用 uni-app 框架以最大限度复用已有 Vue 组件。
- （4）禁止引入未经评估的第三方依赖：所有 Python 第三方依赖须经组内评审后方可加入 `pyproject.toml` 或 `requirements.txt`；仅允许使用 Apache 2.0、MIT、BSD、PSF 等宽松开源许可证的依赖，禁止引入 GPL/AGPL 系协议的库，以规避源码强制开源风险；所有依赖须锁定具体版本（不使用通配符版本号），以保证可复现构建。

2. 数据库与存储约束

- (1) **主数据库固定为 MySQL 8.0+:** 关系型数据持久化统一使用 MySQL 8.0 及以上版本, 存储引擎统一为 InnoDB, 字符集统一为 utf8mb4, 排序规则为 utf8mb4_0900_ai_ci。不得在同一系统中混用 PostgreSQL、Oracle 等其它关系型数据库。
- (2) **缓存与会话存储固定为 Redis 7.0+:** 会话、热点数据缓存与轻量消息队列统一使用 Redis 7.0+; 不得引入 Memcached、Hazelcast 等其它缓存中间件。
- (3) **证据文件采用对象存储:** 第五章规定的证据文件须以对象存储方式持久化, 存储介质为校内 NAS 或兼容 S3 协议的私有对象存储, 文件实体不得直接写入数据库的 BLOB 字段。
- (4) **加密算法固定:** 敏感字段加密统一采用 AES-256-GCM; 文件加密采用 AES-256-CBC 配合”信封加密”模式; 所有加密所需的密钥必须由独立的密钥管理服务 (KMS) 托管, 不得硬编码于源代码或配置文件中。

3. 接入与认证约束

- (1) **身份认证强制对接学校 CAS:** 平台不允许提供独立的注册与密码登录入口, 所有用户身份认证必须通过学校 CAS 单点登录系统完成。CAS 协议版本须遵循校方现有版本 (CAS 3.0), 不得要求校方对现有认证基础设施作任何改造。
- (2) **传输协议强制使用 HTTPS:** 生产环境部署须全站启用 TLS 1.2 及以上版本, 禁用 SSLv3、TLS 1.0、TLS 1.1 等已知存在风险的协议版本; HTTP 端口仅用于强制跳转至 HTTPS。
- (3) **对外接口风格统一:** 对外暴露的应用接口须遵循 RESTful 风格, 响应格式统一采用 JSON, 时间字段统一采用 ISO 8601 格式 (含时区信息), 不得在同一系统中并存 RPC、SOAP 等其它接口风格。

4. 部署与运维约束

- (1) **部署位置受限:** 平台所有服务 (应用服务器、数据库、对象存储、监控组件) 须部署于学校数据中心内网, 禁止使用任何公有云服务托管业务数据, 以满足校内数据不出校的总体要求。
- (2) **操作系统统一为 Linux:** 服务器操作系统统一为 Ubuntu Server 22.04 LTS 或 CentOS Stream 9, 不允许部署于 Windows Server 等其它操作系统。
- (3) **容器化优先:** 应用服务建议以 Docker 容器方式部署, 编排平台推荐 Kubernetes; 如校方运维条件不具备, 则退化为 systemd 托管的标准化部署方式, 但二者必须二选其一, 不得手动启动进程。
- (4) **监控与日志统一:** 系统监控统一接入校方现有 Prometheus + Grafana 体系, 日志统一接入校方

ELK 平台，不得搭建独立的监控与日志栈。

5. 客户端兼容性约束

- (1) 桌面浏览器：仅承诺支持近三个大版本内的 Chrome、Edge、Firefox；不承诺兼容 IE 11 及更早浏览器，亦不为 Safari 在 Windows 平台的旧版本作专门适配。
- (2) 移动端浏览器：移动端仅承诺支持 iOS Safari 13.0 及以上、Chrome for Android 80.0 及以上，对更早版本移动浏览器不作向下兼容承诺。
- (3) 屏幕尺寸：响应式适配最小宽度为 320 px，对低于 320 px 的设备不作显示保证。

6. 技术约束汇总

为便于查阅，将上述技术约束的关键决策点汇总于表 6.1。

表 6.1: 技术约束关键决策汇总

约束类别	选定方案	排除/禁用项
后端语言	Python 3.11+	Python 2.x、Java、Go、Node.js
后端框架	FastAPI 0.110+	Django、Flask、Tornado
ORM 框架	SQLAlchemy 2.x + Alembic	Django ORM、Peewee
Web 服务器	Uvicorn + Gunicorn	uWSGI、Tomcat
前端框架	Vue 3 + TypeScript	React、Angular
UI 组件库	Element Plus	Ant Design Vue、Vuetify
主数据库	MySQL 8.0+ (InnoDB)	PostgreSQL、Oracle、SQL Server
缓存	Redis 7.0+	Memcached、Hazelcast
身份认证	学校 CAS 单点登录	独立注册、第三方 OAuth
传输加密	TLS 1.2+	TLS 1.0/1.1、SSLv3
字段加密	AES-256-GCM + KMS	自实现加密、密钥硬编码
部署位置	学校数据中心内网	公有云托管
操作系统	Ubuntu 22.04 / CentOS 9	Windows Server
监控体系	Prometheus + Grafana	独立监控栈
日志体系	ELK Stack	独立日志栈

(二) 业务约束

业务约束指系统在功能设计与运营过程中所必须遵守的法律法规、组织管理制度及业务流程边界。与技术约束相比，业务约束更难通过技术手段绕过，且违反业务约束的代价通常远高于违反技术约束。

1. 法律法规约束

- (1) 《中华人民共和国反电信网络诈骗法》(2022)：平台作为高校反诈宣传教育的信息化载体，须遵循该法第十一条关于教育主管部门与高校建立反诈宣传教育与信息上报机制的总体要求；

同时，平台不得越位行使侦查、调查、处罚等公权力职能，相关线索的对外传递须通过线下渠道由学校保卫处统一对接公安机关。

- (2) 《中华人民共和国个人信息保护法》(2021)：平台收集与处理用户个人信息须遵循“合法、正当、必要、诚信”原则，具体落实为：最小化收集（仅收集业务必需字段）、显式告知（首次登录时展示隐私政策并要求确认）、目的限定（个人信息不用于反诈业务以外的任何用途）、加密存储（L3 高敏字段强制加密）、可撤回（用户可申请注销账号并触发数据脱敏流程）。
- (3) 《中华人民共和国网络安全法》(2017)：平台作为高校重要信息系统须落实网络安全等级保护制度，建议对照等保第二级要求开展自评；日志留存时间不少于六个月（本平台采用永久留存的更严标准）；系统上线前须完成安全自查与漏洞整改。
- (4) 《中华人民共和国数据安全法》(2021)：平台所收集的数据涉及在校学生敏感信息，原则上属于重要数据范畴，禁止向境外传输；数据出校须经学校信息化主管部门审批。
- (5) 知识产权约束：平台知识库中引用的公开案例须明确标注来源（如“来源于公安部通报”），不得将其它机构的反诈材料未经授权改编后宣称为本校原创。

2. 学校管理制度约束

- (1) 服务对象限定：平台仅向本校在读学生（含本科生、研究生、留学生）及在职教职工开放，不向校友、校外社会人员、合作单位人员开放；账号生命周期与学校 CAS 系统保持一致，毕业或离职后账号自动停用。
- (2) 角色任命须线下授权：审核管理员与系统管理员角色的任命须由学生处、保卫处或信息化建设处书面授权，系统管理员仅根据线下授权文件执行 UC-10 中的角色变更操作，不得自主决定授权对象。
- (3) 敏感操作须线下复核：系统管理员行使“司法协助查询匿名上报者身份”（UC-10 备选 A2）等高敏感操作时，须取得保卫处或学生处的书面同意，仅依靠系统内填写原因不构成完整授权。
- (4) 品牌与视觉规范：平台对外页面须遵循《南开大学视觉识别系统手册》对校徽、校色、字体的使用规范，不得擅自修改校方视觉资产。

3. 业务流程约束

- (1) 事件状态流转单调性：图3.2所定义的状态机为业务硬约束，任何角色（包括系统管理员）均不得跳过中间状态或进行逆向回退。事件一旦进入终态，原始内容与状态记录永久封存。
- (2) 预警发布不可撤销：预警信息一经发布即对目标学生群体生效，仅允许通过“追加后续说明”方式补充信息，禁止删除或修改原始预警内容。这一约束源于预警在公共危机响应中的严肃性要求。

- (3) 知识库审核分级：院系级管理员录入的知识库草稿须经校级管理员复核后方可发布，复核流程不得绕过；这一约束既保证内容质量，也分散单点权力。
- (4) 平台职能边界：平台不参与任何形式的经济损失赔偿、保险理赔、法律援助业务；不与外部公安、银行、运营商系统进行实时数据对接；不向任何商业第三方共享或出售用户数据。
- (5) 时间窗口约束：审核管理员对待审事件的平均处理时长不得超过 48 小时；超时由系统自动催办；连续多次超时记录进入管理员年度考核参考。

4. 业务约束汇总

将上述业务约束的核心要点汇总于表 6.2。

表 6.2: 业务约束核心要点汇总

约束类别	核心要点
法规遵从	反电信网络诈骗法、个保法、网络安全法、数据安全法
职能边界	不行使侦查/执法权；不参与经济赔偿；线索经线下渠道转交
服务对象	仅本校在读学生与在职教职工，不对校外开放
数据出域	L2/L3 数据原则上不出校；出校须经主管部门审批
角色授权	管理员角色任命须线下书面授权
高敏操作	司法协助查询须取得书面同意，系统内填写原因不构成完整授权
状态流转	事件状态机单调推进，禁止跳跃与回退
预警发布	一经发布不可删改，仅可追加说明
处理时效	待审事件平均处理时长 ≤ 48 小时
数据共享	禁止向任何商业第三方共享或出售用户数据

(三) 假设条件

假设条件指系统在分析、设计与实现过程中所默认成立、但平台本身无法直接保证的前提条件。明确这些假设的意义在于：当未来某项假设不成立时，可迅速定位受影响的功能或非功能需求，避免”不知何处出了问题”的局面。本节将假设条件按用户、技术、业务三个维度予以陈列。

1. 用户行为假设

- A1. 真实上报假设：假设绝大多数学生上报的事件信息客观真实，恶意虚报、骚扰式上报为极小概率事件。基于此假设，平台未在 UC-01 中设置复杂的反作弊机制；如未来发现高频虚报，则需追加相应风控逻辑。
- A2. 基本数字素养假设：假设全体在校学生具备使用智能手机与浏览器的基本能力，能够独立完成 CAS 登录、表单填写、文件上传等操作；针对极少数有特殊需求的用户，由辅导员协助代报。

A3. 管理员尽职假设：假设审核管理员在被授权后能够秉持谨慎、公正、保密原则履行职责；平台通过审计日志提供事后监督，但不替代管理员的职业道德。

A4. 使用频次假设：假设单个学生上报频次不高（年均 < 1 次），平台据此规划数据规模；如校内出现大规模诈骗事件导致上报量骤增，则需启动容量扩容预案。

2. 技术环境假设

B1. CAS 服务可用性：假设学校 CAS 单点登录系统的可用性不低于 99.5%，且其接口协议在平台运行期间保持稳定。如 CAS 出现长时间不可用，则平台业务功能整体不可用——这一耦合是有意的设计选择，不构成平台缺陷。

B2. 校园网基础设施：假设校园网核心交换、出口带宽、DNS 等基础设施由信息化建设处持续维护，平台无须自行处理底层网络故障。

B3. 硬件资源充足：假设学校数据中心能够提供第二章表 2.2 规定的最低硬件配置，并预留 50% 的弹性扩容空间用于应对开学初等高并发时段。

B4. 密钥管理服务可用：假设校方提供或允许搭建独立的密钥管理服务（KMS）；如该假设不成立，则需退化为应用层管理密钥的次优方案，但该方案的安全等级将相应降低。

B5. 第三方组件稳定性：假设 Spring Boot、MySQL、Redis 等所选用的开源组件在项目生命周期内不发生导致系统无法运行的重大变更；如发生重大变更，须由维护团队评估升级路径。

3. 业务运行假设

C1. 管理员人力到位：假设学校能够为平台配备足量的审核管理员（建议每千名学生配备至少 1 名院系级管理员），以支撑 48 小时平均处理时长的目标；如人力不足，则该非功能指标须相应放宽。

C2. 诈骗类型相对稳定：假设第三章 UC-01 中预设的八类诈骗手法在平台运行的中短期内仍为主流类型；当出现全新手法时，由审核管理员通过新增 FraudType 字典项的方式扩展，不需修改平台代码。

C3. 反诈宣传需求持续：假设在平台预期的 5 年生命周期内，校园反诈宣传教育的需求持续存在，不会因外部环境根本性变化而消失。

C4. 数据规模符合估算：假设第五章表 5.34 中给出的 5 年数据量估算与实际情况的偏差不超过 50%；如实际增长显著超过估算，须按 5.6.3 节末段所述的归档与分区策略提前介入。

C5. 法规体系延续性：假设《反电信网络诈骗法》《个人信息保护法》等核心法规在平台生命周期内保持总体延续，重大修订时由项目维护团队评估其对平台的影响并相应调整。

4. 假设条件汇总

为便于后续追踪与风险管理，将所有假设条件汇总于表 6.3，并标注每条假设若不成立时所影响的主要功能或非功能需求。

表 6.3: 假设条件汇总与影响分析

编号	假设内容简述	假设不成立时受影响的需求
A1	上报内容真实，无大规模虚报	UC-01；需追加反作弊机制
A2	学生具备基本数字素养	UC-01/02/05；易用性需求
A3	管理员尽职尽责	UC-06/07/08；安全性需求
A4	单个学生上报频次低	第五章数据规模估算
B1	CAS 服务可用性 $\geq 99.5\%$	UC-00 及全部业务功能
B2	校园网基础设施稳定	第四章性能需求
B3	硬件资源充足	第四章性能与可用性需求
B4	KMS 服务可用	第四章安全性需求中的加密存储
B5	关键开源组件稳定	系统整体可维护性
C1	管理员人力到位	48 小时平均处理时长
C2	诈骗类型相对稳定	UC-01 分类体系；知识库
C3	反诈宣传需求持续	项目立项依据
C4	数据量估算偏差 $\leq 50\%$	第五章存储与索引设计
C5	核心法规延续	第四章合规性需求

(四) 约束与假设的整体说明

约束与假设并非孤立存在，三者之间存在如下层次关系：技术约束界定了系统的实现边界，业务约束界定了系统的功能边界，而假设条件则界定了系统正确运行所需的外部前提。本章所列各项内容均来源于第二章至第五章的具体需求描述，并非凭空增加的限制。未来在系统的设计、实现与维护过程中，如发现某项约束与具体设计方案产生冲突，应由项目组主导评审：若约束属于第（一）节技术类别且无监管含义，可在记录变更原因的前提下调整；若属于第（二）节业务类别，原则上不得绕过，须经学校相关主管部门书面同意后方可调整。对于第（三）节中的假设条件，建议每次大版本迭代时进行复核，及时识别已不再成立的前提，避免基于失效假设作出错误决策。

至此，本文档对“校园电信诈骗上报与预警平台”的引言、系统概述、功能性需求、非功能性需求、数据需求以及约束与假设进行了完整的描述，可作为后续概要设计、详细设计与原型开发工作的统一输入依据。